MATERIAL DE ESTUDO

SEGURANÇA DA INFORMAÇÃO

Guia de Estudo — Edição Ilustrada



Dos fundamentos à engenharia: ameaças, criptografia, identidade, redes, desenvolvimento seguro, operação e resposta a incidentes — com termos técnicos, padrões e estratégias de defesa.

20 MÓDULOS | 150+ TERMOS | OWASP · NIST · ISO | DEFESA EM CAMADAS

EDIÇÃO DE ESTUDO · VERSÃO OUT/2026

ÍNDICE

SUMÁRIO

Do vocabulário e das ameaças à criptografia, à identidade, às redes e ao desenvolvimento seguro — e daí à operação, à resposta a incidentes e a um projeto completo. Cada módulo funciona sozinho.

—	**Como usar este guia** Mapa dos 20 módulos, legenda dos quadros, trilhas de estudo e pré-requisitos	03
01	**Fundamentos da segurança** Tríade CIA, AAA, ameaça × vulnerabilidade × risco, princípios de projeto e defesa em profundidade	05
02	**Ameaças e ataques** Atores, malware, ransomware, engenharia social, ataques a credenciais, DoS e MITRE ATT&CK	11
03	**Riscos e modelagem de ameaças** Gestão de risco, ALE, matriz de risco, STRIDE, diagramas de fluxo, CVSS, EPSS e KEV	20
04	**Normas, leis e conformidade** ISO 27001/27002, NIST CSF 2.0, CIS Controls, PCI DSS, LGPD, Marco Civil e leis penais	27
—	**Glossário técnico** Termos de A a Z para consulta rápida, com siglas e conceitos usados no guia	34

ANTES DE COMEÇAR

— COMO USAR ESTE GUIA

Um mapa rápido para tirar o máximo do material — dos conceitos ao projeto de um sistema seguro.

Este guia reúne os principais **termos, padrões, técnicas e estratégias de engenharia** da segurança da informação — dos fundamentos ao projeto de um sistema seguro. A ordem vai do "o quê e por quê" ao "como construir e operar", mas cada módulo funciona sozinho.

MAPA DO GUIA

1 · ENTENDER
Fundamentos e contexto

- 01 Fundamentos da segurança
- 02 Ameaças e ataques
- 03 Riscos e modelagem de ameaças
- 04 Normas, leis e conformidade

2 · PROTEGER
Dados e identidades

- 05 Criptografia aplicada
- 06 Identidade e autenticação
- 07 Autorização e controle de acesso
- 08 Proteção de dados e privacidade

3 · INFRAESTRUTURA
Redes e ambientes

- 09 Segurança de redes
- 10 Sistemas, nuvem e contêineres

4 · DESENVOLVER
Segurança no desenvolvimento

- 11 Ciclo de vida seguro (SSDLC)
- 12 Segurança web e OWASP Top 10
- 13 APIs, mobile e sistemas de IA
- 14 Código seguro e memória
- 15 Cadeia de suprimentos e DevSecOps

5 · OPERAR
Detecção, resposta e testes

- 16 Monitoramento e detecção
- 17 Resposta a incidentes
- 18 Testes de segurança

6 · PRATICAR
Consolidação

- 19 Pessoas e proteção pessoal
- 20 Projeto-guia: sistema seguro

Seis blocos, do entendimento à prática. Os números dentro de cada bloco são os módulos; o sumário mostra a página de cada um.

LEGENDA DOS QUADROS

Em resumo: a ideia central de uma seção, em uma ou duas frases. Ótimo para revisar.

Boa prática: um controle ou hábito que funciona na prática e vale virar rotina.

Atenção: um erro comum ou um risco real. Leia antes de seguir em frente.



DICA DA CORUJA

o conselho de quem já viu isso dar errado: um atalho, um critério de decisão ou uma regra de bolso.

EXEMPLO RESOLVIDO · ESTUDO DE CASO

Blocos escuros como este trazem **cálculos resolvidos, incidentes reais e exemplos de projeto**. Acompanhe o raciocínio com papel e caneta e refaça com os números do seu cenário.

— COMO USAR ESTE GUIA

CONTINUAÇÃO

TRILHAS DE ESTUDO

SEU PERFIL	COMECE POR	DEPOIS	FIXE COM
Primeira disciplina de segurança	p. 5 → p. 11 → →	→ →	Projeto-guia () e glossário (p. 34)
Quero desenvolver software seguro	→ →	→ → →	Checklists dos módulos e projeto-guia ()
Infraestrutura e operações (*blue team*)	→ → →	p. 20 → p. 27 →	Playbooks e exercícios de
Segurança ofensiva, de forma ética	p. 11 → →	→ →	Laboratórios legais indicados em
Gestão, risco e conformidade (GRC)	p. 5 → p. 20 → p. 27	→ →	Matriz de risco e quadro de controles
Revisão rápida em 1 hora	Quadros "Em resumo" de cada módulo	Perguntas "Para fixar"	Glossário (p. 34)

COMO LER O TEXTO

Termos e código

Termos em inglês aparecem em itálico na primeira vez. `Comandos`, arquivos e trechos de código ficam em fonte monoespaçada; em blocos de comparação, linhas em vermelho são inseguras e em verde, corretas.

Referências de página

Indicações como levam ao início do módulo citado. No PDF digital, elas, o sumário e as fontes são clicáveis. Cada módulo termina com "Para fixar" e "Aprofunde-se".

Datas e números

Padrões e relatórios mudam (OWASP, NIST, CWE, DBIR). Este guia reflete **outubro de 2026**; confira a edição vigente nas fontes ().

ÉTICA E LEGALIDADE PRIMEIRO

Atenção: este material é **defensivo e educacional**. Pratique somente em sistemas seus ou em laboratórios feitos para isso. Testar, invadir ou interferir em sistemas de terceiros **sem autorização é crime** no Brasil (Código Penal, art. 154-A, incluído pela Lei nº 12.737/2012 e agravado pela Lei nº 14.155/2021). Detalhes em p. 27 e .

O QUE VOCÊ PRECISA SABER ANTES

Não é pré-requisito

- Ser especialista em redes, sistemas ou criptografia
- Programar em uma linguagem específica
- Conhecer ferramentas de ataque

Ajuda bastante

- Noções de redes (IP, porta, DNS, HTTP) e de sistemas operacionais (processo, permissão)
- Lógica de programação, SQL básico e Git
- Matemática discreta: módulo, potências e probabilidade (para criptografia e risco)
- Um laboratório pequeno: uma máquina virtual e um alvo de treino como o OWASP Juice Shop

MÓDULO 01 · FUNDAMENTOS

01 FUNDAMENTOS DA SEGURANÇA

O vocabulário e os princípios que sustentam todo o resto: o que se protege, de quem e como se pensa a defesa.

Segurança da informação é proteger a informação — em qualquer meio e em todo o seu ciclo de vida — contra acesso, alteração, destruição ou indisponibilidade indevidos. Este módulo fixa o vocabulário e os princípios de projeto que sustentam todos os outros: sem eles, controles viram uma lista de ferramentas sem critério.

O QUE SE PROTEGE: SI, CIBERSEGURANÇA E VIZINHOS

TERMO	FOCO	EXEMPLO
Segurança da informação (SI)	Proteção da informação em qualquer meio (digital, papel, conversa) e em todo o ciclo de vida	Mesa limpa, backup, controle de acesso a documentos
Cibersegurança	Proteção de sistemas, redes e dados no ambiente digital contra ataques	MFA, EDR, firewall, WAF
Segurança de aplicações e sistemas	Propriedades de segurança do software e da infraestrutura em que ele roda	Validação de entrada, *hardening*, gestão de patches
Privacidade	Uso adequado de dados pessoais e respeito aos direitos do titular (finalidade, consentimento)	LGPD, minimização de dados, direito de acesso
***Safety* (segurança operacional)**	Evitar danos a pessoas e ao ambiente causados por falhas — em português, também se diz "segurança"	Intertravamento de uma máquina industrial

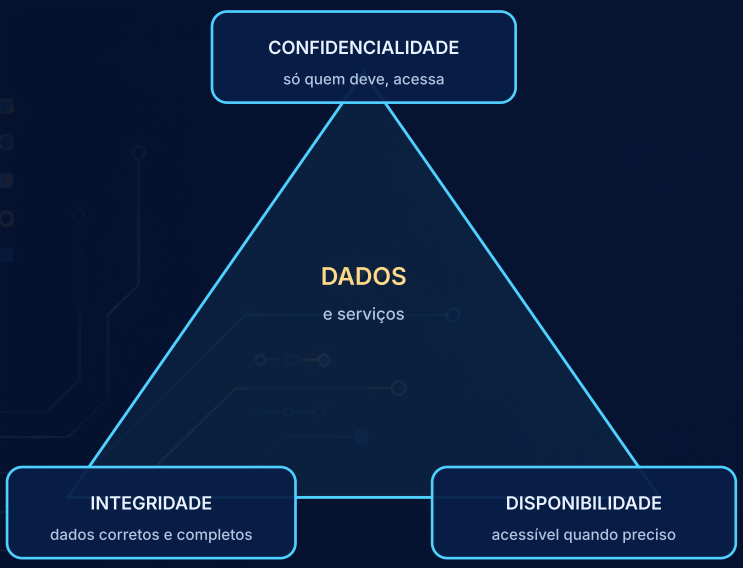
VOCABULÁRIO ESSENCIAL

TERMO	DEFINIÇÃO	EXEMPLO
Ativo (*asset*)	Tudo que tem valor e precisa de proteção: dados, sistemas, pessoas, reputação	Banco de notas dos alunos; servidor de provas
Ameaça (*threat*)	Causa potencial de um incidente indesejado: evento ou ator com capacidade de causar dano	Grupo de ransomware; erro humano; incêndio
Agente de ameaça (*threat actor*)	Quem ou o que concretiza a ameaça	Cibercriminoso, *insider*, Estado, *malware* autônomo
Vulnerabilidade	Fraqueza em um ativo, processo ou controle que uma ameaça pode explorar	Biblioteca sem correção; senha padrão; falta de treinamento
Exploit	Técnica ou código que aproveita uma vulnerabilidade específica	Código que explora o Log4Shell (CVE-2021-44228)
Vetor de ataque	Caminho usado para chegar ao alvo	E-mail de phishing; serviço exposto na internet; USB
Superfície de ataque	Soma de todos os pontos de entrada e saída de dados que um atacante pode alcançar	APIs, portas abertas, contas, dependências, pessoas

01 FUNDAMENTOS DA SEGURANÇA — CONTINUAÇÃO

TERMO	DEFINIÇÃO	EXEMPLO
Risco	Combinação da probabilidade de uma ameaça explorar uma vulnerabilidade com o impacto resultante	Alta chance de vazamento por credencial fraca × multa e perda de confiança
Impacto	Consequência medida: financeira, operacional, legal, reputacional	Três dias parados; multa; perda de clientes
Controle (contramedida)	Medida que reduz a probabilidade ou o impacto de um risco	MFA, backup, política, câmera
Evento × incidente	Evento: ocorrência observável. Incidente: evento (ou série) que compromete a CIA ou viola a política	Login falho (evento); conta de administrador tomada (incidente)

TRÍADE CIA E PROPRIEDADES ESTENDIDAS



PROPRIEDADES ESTENDIDAS

Autenticidade
a origem é comprovada: é mesmo quem diz ser

Não repúdio
o autor não pode negar a ação (assinatura digital)

Responsabilização (accountability)
ações rastreáveis a uma identidade (logs, auditoria)

Privacidade
dado pessoal tratado só para a finalidade informada

Confiabilidade (reliability)
o sistema se comporta como esperado

A tríade CIA e o que a cerca. Todo controle de segurança existe para proteger ao menos uma destas propriedades; as extensões à direita aparecem em normas, leis e arquiteturas de identidade.

PROPRIEDADE	COMO É VIOLADA	CONTROLES TÍPICOS	CASO PARA LEMBRAR
Confidencialidade	Vazamento, interceptação, acesso indevido	Cifragem, controle de acesso, classificação de dados	Equifax (2017): ao menos 145,5 milhões de pessoas expostas (GAO)
Integridade	Alteração não autorizada de dados, código ou configuração	Hash, assinatura digital, controle de versão, logs imutáveis	SolarWinds (2020): atualização legítima adulterada na origem
Disponibilidade	Negação de serviço, ransomware, falha de hardware ou de software, desastre	Redundância, backups testados, mitigação de DDoS, plano de DR	CrowdStrike (2024): milhões de máquinas fora do ar — sem ataque algum

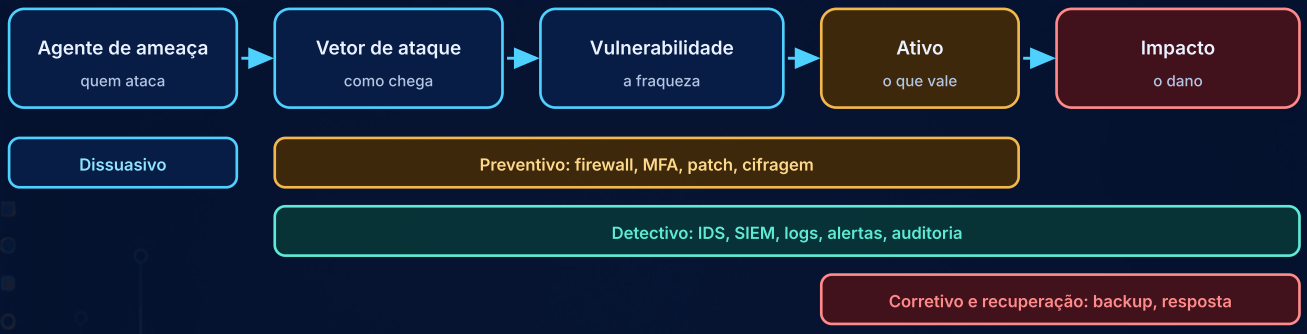
AAA descreve a cadeia que transforma "alguém bate à porta" em uma decisão registrada: a pessoa ou o sistema se **identifica**, **prova** quem é (autenticação), recebe apenas o que pode fazer (autorização) e tem as ações **registradas** (*accounting*, auditoria). Falhar em qualquer elo enfraquece todos os outros.

01 **FUNDAMENTOS DA SEGURANÇA** CONTINUAÇÃO



Em resumo: CIA é um modelo de **objetivos**; os controles são os **meios**. Um mesmo incidente costuma violar várias propriedades — no ransomware com dupla extorsão, a disponibilidade (arquivos cifrados) e a confidencialidade (dados roubados e ameaçados de publicação).

TIPOS DE CONTROLE: FUNÇÃO × NATUREZA



Onde cada tipo de controle atua. Dissuasivos desencorajam o agente; preventivos reduzem a chance de a vulnerabilidade ser explorada; detectivos revelam o que passou; corretivos e de recuperação limitam o impacto. Controles compensatórios substituem um controle que não pode ser aplicado.

FUNÇÃO	ADMINISTRATIVO	TÉCNICO	FÍSICO
Preventivo	Política de acesso, treinamento, separação de funções	Firewall, MFA, cifragem, patches	Cadeado, catraca, controle de acesso ao datacenter
Detectivo	Auditorias, revisão de logs, inspeções	IDS, SIEM, verificação de integridade	Câmeras, sensores de movimento, alarme
Corretivo	Plano de resposta a incidentes, lições aprendidas	Restaurar backup, aplicar correção, isolar host	Extintor, reparo ou troca de hardware
Dissuasivo	Sanções disciplinares, termos de uso	Banner de aviso de monitoramento	Cercas, placas, câmeras visíveis
Compensatório	Revisão dupla quando não há separação de funções	*Virtual patching* em WAF; segmentação extra	Vigilância adicional enquanto a porta é consertada
Recuperação	Plano de continuidade e de recuperação de desastres	Sistemas redundantes, restauração automatizada	Sítio alternativo, gerador de energia

PRINCÍPIOS DE PROJETO: SALTZER E SCHROEDER (1975)

Oito princípios publicados há meio século continuam sendo o vocabulário comum de quem projeta sistemas seguros. A tabela traduz cada um e mostra como aparece hoje.

01 FUNDAMENTOS DA SEGURANÇA — CONTINUAÇÃO

PRINCÍPIO	IDEIA	COMO APLICAR HOJE
Economia de mecanismo (*economy of mechanism*)	Projetos simples e pequenos são mais fáceis de entender, testar e verificar	Menos código, menos dependências, menos funcionalidades expostas
Padrões à prova de falhas (*fail-safe defaults*)	Por padrão, o acesso é negado; permissões são concedidas, não retiradas	*Deny by default* em firewall e em autorização
Mediação completa (*complete mediation*)	Todo acesso a todo objeto é verificado, sempre	Autorização em toda requisição, **no servidor**
Projeto aberto (*open design*)	A segurança não pode depender do segredo do projeto, só das chaves (princípio de Kerckhoffs)	Algoritmos públicos como o AES; código auditável
Separação de privilégios (*separation of privilege*)	Ações críticas exigem mais de uma condição ou pessoa	MFA, aprovação em dupla (*four eyes*)
Menor privilégio (*least privilege*)	Cada entidade recebe o mínimo necessário, pelo menor tempo possível	Papéis enxutos, tokens com escopo, acesso sob demanda (JIT)
Menor mecanismo comum (*least common mechanism*)	Minimizar o que é compartilhado entre usuários, para limitar a propagação de falhas	Isolamento entre clientes (*tenants*), contêineres, contas separadas
Aceitabilidade psicológica (*psychological acceptability*)	Controles difíceis de usar são contornados	SSO, *passkeys*, mensagens de erro claras e fluxos curtos

Princípios modernos

- **Defesa em profundidade:** várias camadas independentes
- **Falhar de forma segura** (*fail securely*): o erro nega, não libera
- **Seguro por projeto e por padrão** (*secure by design / default*)
- **Zero Trust:** nada é confiável só por estar "dentro" da rede
- **Assuma o comprometimento** (*assume breach*): projete para detectar e conter

Um mito a evitar

Segurança por obscuridade — esconder o projeto, a porta ou o endereço — não é um controle, é um atraso. Pode complementar defesas reais, mas nunca substituí-las: se o sistema só é seguro enquanto ninguém souber como ele funciona, ele não é seguro.

SUPERFÍCIE DE ATAQUE E FRONTEIRAS DE CONFIANÇA

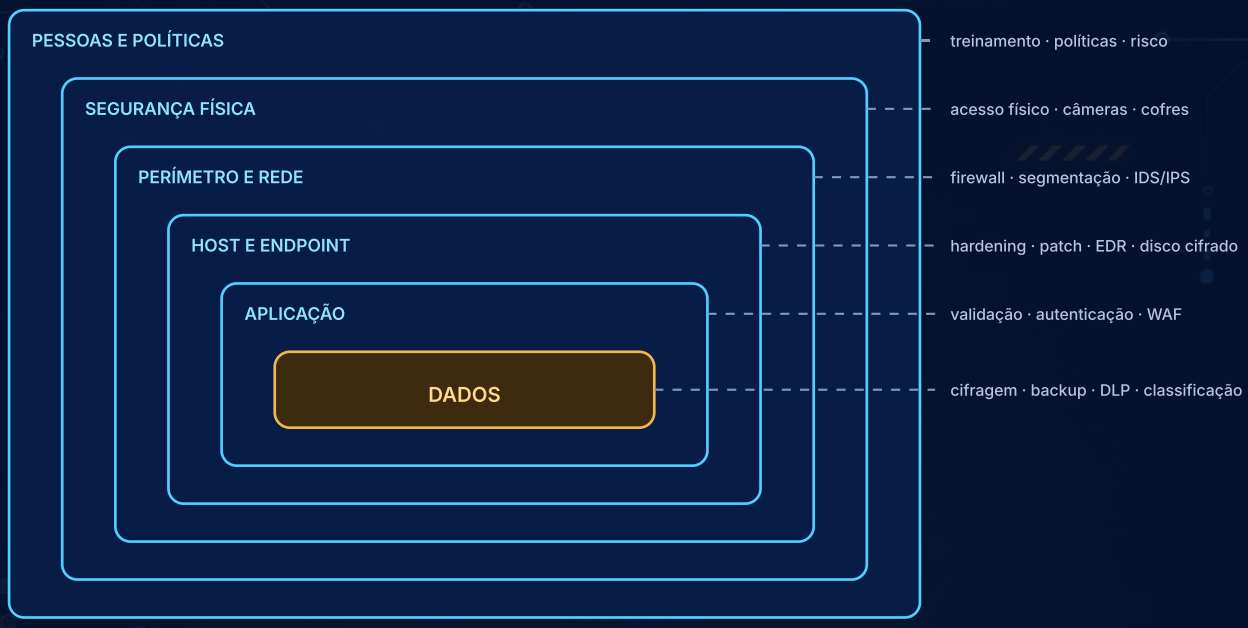
A **superfície de ataque** é tudo o que um adversário pode tocar: portas e serviços, APIs, formulários, contas, dependências de software, dispositivos, fornecedores e as próprias pessoas. Reduzi-la é um dos ganhos mais baratos em segurança: **desligue** o que não usa, **exponha** menos, **valide** mais e **remova** acessos antigos.

Uma **fronteira de confiança** (*trust boundary*) é o ponto em que os dados passam de um nível de confiança a outro — da internet para o servidor web, do servidor para o banco, de um cliente (*tenant*) para outro. É ali que se concentram autenticação, validação e registro. Aprofundamos o desenho de fronteiras em p. 20.

01 FUNDAMENTOS DA SEGURANÇA

CONTINUAÇÃO

DEFESA EM PROFUNDIDADE



Camadas independentes. Se uma falha, a seguinte reduz o dano e dá tempo de detectar. Nenhuma camada sozinha basta — e uma camada fraca não é compensada por repetir controles da mesma natureza.

Atenção: defesa em profundidade **não** é "mais do mesmo". Três firewalls do mesmo fabricante com a mesma regra falham juntos; camadas distintas (rede, host, aplicação, dados, pessoas) falham por motivos diferentes.

TRADE-OFFS: NENHUM SISTEMA É 100% SEGURO

Segurança × usabilidade

Controle que atrapalha o trabalho é contornado: senha em post-it, compartilhamento de conta, *shadow IT*. O caminho seguro precisa ser o mais fácil.

Atacante × defensor

Quem defende precisa cobrir tudo, sempre; quem ataca precisa de uma brecha. Por isso: reduzir superfície, detectar cedo e projetar assumindo que algo falhará.

Custo × risco

Um controle não deve custar mais do que o risco que reduz (veja o cálculo do ALE em **p. 20**). Priorize pelo risco real, não pelo medo nem pela moda.

DICA DA CORUJA

Antes de adotar qualquer ferramenta, responda por escrito: **"protege qual ativo, de qual ameaça, com qual controle e como vou saber que funciona?"** Se não souber responder, ainda não é um controle — é só um produto.

QUEM FAZ O QUÊ: PAPÉIS EM SEGURANÇA

PAPEL	FOCO	ONDE APROFUNDAR
Gestão de segurança (CISO)	Estratégia, orçamento, risco e diálogo com a diretoria	p. 20, p. 27
Analista de SOC e resposta a incidentes	Monitorar, triar alertas, conter e investigar incidentes	,

01 FUNDAMENTOS DA SEGURANÇA — CONTINUAÇÃO

PAPEL	FOCO	ONDE APROFUNDAR
Engenharia de segurança de aplicações (AppSec)	Ciclo de vida seguro, revisão de código, ferramentas no pipeline	, ,
Pentester e *red team*	Testes de intrusão autorizados e emulação de adversário	
Arquitetura e engenharia de infraestrutura e nuvem	Rede, identidade, *hardening*, contêineres	,
GRC, conformidade e privacidade (encarregado/DPO)	Normas, auditoria, LGPD e relação com a ANPD	p. 27,

EXEMPLO RESOLVIDO

Cenário. Em um portal acadêmico, um aluno explora uma falha de autorização, altera as próprias notas e, no mesmo acesso, baixa a lista de e-mails da turma.

Classificação CIA. Integridade violada (notas alteradas); confidencialidade violada (e-mails expostos); disponibilidade preservada.

O que faltou. Autorização verificada no servidor em cada operação (princípio da mediação completa —); registro e alerta de alterações de notas (responsabilização —); minimização do que a página de turma expõe ().

PARA FIXAR

Conceitos

- Diferencie ameaça, vulnerabilidade e risco com um exemplo seu.
- Por que "projeto aberto" não significa publicar as chaves?
- Dê um exemplo de controle detectivo técnico e um corretivo administrativo.

Aplicação

- Classifique nos eixos CIA: vazamento de e-mails, preços alterados e site fora do ar na Black Friday — e proponha um controle preventivo para cada.
- Aplique a defesa em profundidade a uma pasta com TCCs: um controle por camada.
- Cite dois controles que violam a aceitabilidade psicológica e como melhorá-los.

APROFUNDE-SE

Leituras e referências

- The Protection of Information in Computer Systems — Saltzer e Schroeder, *Proceedings of the IEEE* (1975): a fonte dos oito princípios.
- NIST Computer Security Resource Center — Glossary — definições oficiais de centenas de termos.
- Security Engineering — Ross Anderson (3ª ed.): capítulos abertos sobre fundamentos e economia da segurança.
- Building Secure and Reliable Systems — Google (livro aberto): princípios de projeto na prática.
- Cartilha de Segurança para Internet — CERT.br/NIC.br: linguagem acessível, em português.

MÓDULO 02 · FUNDAMENTOS

02 AMEAÇAS E ATAQUES

Quem ataca, por que e como: o cenário de ameaças e os modelos que organizam o conhecimento sobre ataques.

Defender bem exige entender **quem ataca, por quê e como**. Este módulo apresenta os agentes de ameaça, as grandes famílias de ataque e os modelos que organizam o raciocínio de quem protege — *Kill Chain*, MITRE ATT&CK e *Pyramid of Pain* — sempre com foco em **detectar, prevenir e interromper**.

PANORAMA: O QUE OS RELATÓRIOS MOSTRAM

31%
dos acessos iniciais vieram da exploração de vulnerabilidades, o vetor mais comum
VERIZON DBIR 2026

62%
das violações envolveram o elemento humano: erro, phishing ou credenciais
VERIZON DBIR 2026

48%
das violações envolveram terceiros (eram 30% no ano anterior)
VERIZON DBIR 2026

US$ 4,99
milhões: custo médio global de uma violação de dados, alta de 12%
IBM · 2026

O abuso de credenciais respondeu por 13% dos acessos iniciais e o ransomware esteve presente em 48% das violações. Um dado revela o problema de fundo: só **26%** das vulnerabilidades críticas do catálogo KEV foram totalmente corrigidas em 2025, e o tempo mediano de correção subiu de 32 para 43 dias. Ou seja, boa parte dos ataques bem-sucedidos usa **falhas conhecidas** e **identidades fracas** — e a resposta é, em grande medida, higiene: correção, MFA, menor privilégio e backup.

Como ler os números: relatórios têm metodologias e amostras próprias: use-os para enxergar **tendências**, não como retrato exato da sua organização. Os valores acima seguem a cobertura especializada das edições de 2026; confira-os nas fontes originais ().

AGENTES DE AMEAÇA

Um **agente de ameaça** (*threat actor*) se descreve por **motivação**, **capacidade** e **oportunidade**. Saber contra quem você projeta a defesa — o chamado *modelo de adversário*, detalhado em p. 20 — muda quais controles valem o custo.

AGENTE	MOTIVAÇÃO	CAPACIDADE E RECURSOS	ALVOS TÍPICOS
Oportunista (*script kiddie*)	Curiosidade, notoriedade	Baixa: usa ferramentas e scripts prontos	Sistemas expostos com falhas conhecidas
Hacktivista	Causa política ou social	Baixa a média: DDoS, pichação de sites, vazamentos	Governos e empresas controversas
Cibercriminoso (inclui RaaS e corretores de acesso)	Lucro financeiro	Média a alta: mercado organizado e especializado	Qualquer organização com dados ou receita
Crime organizado	Lucro em escala, lavagem	Alta: infraestrutura própria, fraude e extorsão	Bancos, meios de pagamento, varejo

02 AMEAÇAS E ATAQUES

CONTINUAÇÃO

AGENTE	MOTIVAÇÃO	CAPACIDADE E RECURSOS	ALVOS TÍPICOS
Insider (malicioso, negligente ou comprometido)	Dinheiro, vingança, descuido	Variável: já possui acesso legítimo	Dados e sistemas da própria organização
APT / Estado-nação	Espionagem, sabotagem, influência	Muito alta: recursos, paciência e falhas inéditas (*zero-days*)	Governo, defesa, energia, cadeia de suprimentos



DICA DA CORUJA

defina o adversário **antes** de escolher controles: "contra quem, com quais recursos, atrás de quê?". Proteger um blog pessoal de um Estado é desperdício; proteger um banco só com antivírus é negligência.

MALWARE: FAMÍLIAS, COMPORTAMENTO E DEFESA

Malware (*malicious software*) é todo software feito para causar dano ou obter acesso não autorizado. As categorias se sobrepõem — um mesmo programa pode ser *trojan*, *loader* e ransomware ao mesmo tempo. O que se detecta, portanto, é o **comportamento**, mais do que o rótulo.

TIPO	COMO AGE OU SE PROPAGA	SINAIS E DEFESA
Vírus	Anexa-se a arquivos ou programas e precisa que o hospedeiro seja executado	Antimalware/EDR, assinatura de código, *allowlisting*
Worm (verme)	Propaga-se sozinho pela rede explorando falhas (WannaCry usou SMBv1)	Correção de falhas, segmentação, bloqueio de SMB entre estações
Trojan (cavalo de troia)	Disfarça-se de software legítimo e entrega outras cargas	Instalar só de fontes confiáveis, reputação, *sandbox*
Ransomware	Cifra dados e, hoje, quase sempre também os exfiltra, para exigir pagamento	Backups imutáveis, EDR, menor privilégio, segmentação
Spyware / *infostealer*	Coleta senhas, *cookies* de sessão e dados do navegador	MFA resistente a phishing, sessões curtas, EDR ()
Rootkit / bootkit	Oculta a presença no sistema, no *kernel* ou na inicialização (*boot*)	*Secure Boot*, TPM e atestação, verificação de integridade
Botnet / RAT	Máquinas controladas à distância por um servidor C2; a Mirai (2016) usou IoT com senha padrão	Trocar senhas padrão, filtro de saída, detecção de *beaconing*
Fileless* / *living off the land	Abusa de ferramentas legítimas do sistema (PowerShell, WMI) e da memória	Registro de scripts, EDR comportamental, restringir ferramentas
Wiper	Destrói dados de forma irrecuperável; o NotPetya (2017) imitava ransomware	Backups offline, segmentação, recuperação ensaiada

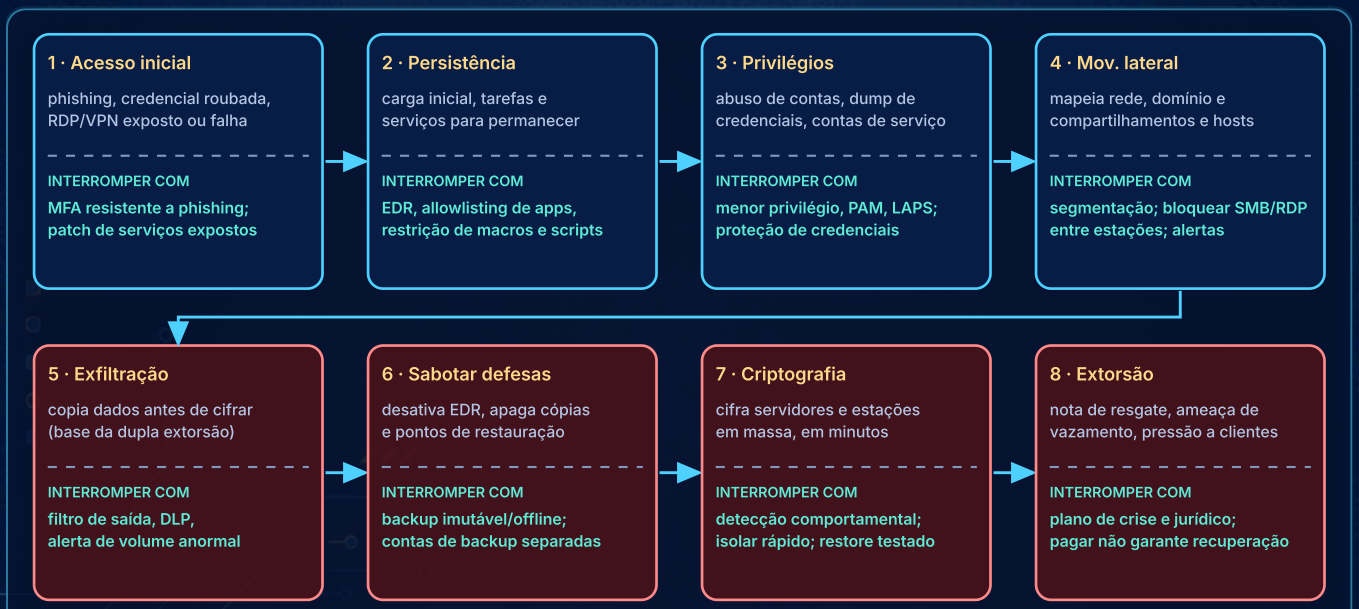
Atenção: antivírus baseado só em **assinaturas** (hashes) é insuficiente: basta recompilar para o hash mudar (veja a *Pyramid of Pain* adiante). Combine detecção comportamental, *allowlisting*, correção de falhas e backup.

02 **AMEAÇAS E ATAQUES** CONTINUAÇÃO

RANSOMWARE: ECONOMIA E CICLO DE ATAQUE

Ransomware é um negócio, não só um programa. No modelo *Ransomware-as-a-Service* (RaaS), os desenvolvedores alugam a plataforma a **afiliados**, que invadem as vítimas e dividem o resgate. **Corretores de acesso inicial** (*initial access brokers*) vendem credenciais e acessos prontos. A pressão cresceu em camadas: a **dupla extorsão** (cifrar *e* ameaçar vazar os dados) e a **tripla extorsão** (somar DDoS ou pressão sobre clientes e parceiros). Em maio de 2021, o ataque do grupo DarkSide à Colonial Pipeline levou a operação a ser interrompida por precaução (alerta CISA AA21-131A).

O backup comum não basta: os operadores procuram e apagam as cópias **antes** de cifrar. A regra **3-2-1-1-0** — 3 cópias, 2 mídias, 1 fora do local, 1 offline ou imutável e 0 erros na verificação de restauração — e o **teste periódico de restauração** são o que separa um incidente de uma catástrofe.



azul: intrusão e preparo (a vítima ainda opera) · vermelho: fase de impacto, quando o dano fica visível

Ciclo típico de um ataque de ransomware. Cada etapa tem um ponto de interrupção: nas quatro primeiras a vítima ainda opera normalmente e só a detecção percebe; quando a criptografia começa, só a preparação (backup, segmentação, plano de crise) salva.

> **Boa prática:** meça o que importa: **RTO** (tempo máximo para voltar a operar) e **RPO** (quanto dado se aceita perder). Ensaie a restauração completa pelo menos uma vez por ano e guarde, fora do domínio, o procedimento impresso ou offline ().

ENGENHARIA SOCIAL

A **engenharia social** manipula **pessoas**, não sistemas: explora confiança, pressa e respeito à autoridade. Por isso está na origem de grande parte dos incidentes — o phishing foi o vetor inicial mais comum no relatório da IBM de 2026, pelo quarto ano seguido. As alavancas psicológicas descritas por **Robert Cialdini** explicam por que ela funciona.

TÉCNICA	CANAL E MECANISMO	SINAL DE ALERTA	DEFESA
Phishing	E-mail em massa com link ou anexo falso	Urgência; remetente ou URL quase igual ao legítimo	Filtro de e-mail, DMARC, MFA resistente a phishing
Spear phishing	Mensagem personalizada para uma pessoa ou área	Conhece detalhes internos; pede ação específica	Verificar por outro canal; treinamento

02 AMEAÇAS E ATAQUES

CONTINUAÇÃO

TÉCNICA	CANAL E MECANISMO	SINAL DE ALERTA	DEFESA
***Whaling* / BEC**	Fraude contra executivos e financeiro: pagamento, troca de conta	Pedido incomum de transferência ou sigilo	Dupla aprovação; ligar de volta para número conhecido
Vishing* / *smishing	Ligação de voz e SMS	Pede código, senha ou instalar aplicativo	Nunca informar códigos; desligar e ligar de volta
Quishing	QR Code malicioso em e-mail, cartaz ou adesivo	Código em local inesperado	Pré-visualizar o endereço; filtro de URL móvel
Pretexting	Cenário inventado (TI, RH, fornecedor) para obter dados	Ignora o procedimento padrão	Procedimento fixo de verificação de identidade
***Deepfake* de voz ou vídeo**	Clone da voz ou do rosto de um superior ou parente	Urgência + sigilo + pedido de pagamento	Palavra combinada; confirmar fora do canal
MFA fatigue	Dezenas de pedidos de aprovação até alguém aceitar (caso Uber, 2022)	Notificações que você não iniciou	Correspondência de número, FIDO2, limite de tentativas

Reciprocidade

Um favor cria obrigação: o "técnico" que ajuda de graça e depois pede um acesso.

Compromisso e coerência

Um pequeno "sim" leva a outro: começa com um pedido inocente e escala.

Prova social

"Todo mundo já fez": "seus colegas já atualizaram o cadastro".

Autoridade

Chefe, banco, TI ou polícia: obedece-se a quem parece ter poder.

Afinidade

Simpatia e semelhança: perfil falso amigável, com interesses em comum.

Escassez e urgência

"Só hoje", "sua conta será bloqueada em 1 hora": a pressa desliga o espírito crítico.



DICA DA CORUJA

toda mensagem que junta **urgência + autoridade + pedido incomum** (pagar, informar um código, instalar algo) merece verificação por **outro canal**. A IA generativa barateou textos perfeitos e vozes clonadas, então "erros de português" já não denunciam golpe: confie no **processo**, não na "cara de golpe".

ATAQUES A CREDENCIAIS

Credenciais são a moeda do ataque moderno. Em vez de "quebrar" sistemas, o adversário **entra com uma identidade válida** — e passa despercebido. As defesas completas (hash de senha, MFA, passkeys) estão em ; aqui o foco é entender o ataque.

ATAQUE	COMO FUNCIONA	DEFESA PRINCIPAL
Força bruta	Testa combinações até acertar, online ou contra um hash roubado	Senhas longas, limite de tentativas, hash lento (Argon2id)
Dicionário e regras	Testa senhas prováveis e suas mutações (*Verao2026!*)	Checar contra listas de senhas vazadas; sem regras de composição
Credential stuffing	Reaproveita pares usuário/senha vazados de um site em outros	Senha única por serviço, MFA, detecção de bots

02 AMEAÇAS E ATAQUES

CONTINUAÇÃO

ATAQUE	COMO FUNCIONA	DEFESA PRINCIPAL
Password spraying	Poucas senhas comuns contra muitas contas, para fugir do bloqueio	Alertas por origem e por senha, MFA, bloqueio inteligente
Interceptação / AiTM	Captura senha e *cookie* com proxy de phishing (*adversary-in-the-middle*), *sniffing* ou *keylogger*	FIDO2/passkeys, TLS, EDR
Pass-the-hash	Reutiliza o hash NTLM roubado, sem conhecer a senha (ambientes Windows/AD)	Segmentação, restringir administrador local, LAPS, proteção de credenciais
Kerberoasting	Pede tickets de serviço e quebra a senha da conta de serviço offline	Contas de serviço com senha longa ou gMSA, AES, detecção
SIM swap	Transfere o número da vítima para outro chip e recebe SMS e códigos	Evitar SMS como MFA, PIN na operadora, FIDO2

Atenção: bloquear a conta após N tentativas pode virar um **ataque de negação de serviço contra usuários legítimos** (o adversário trava contas alheias de propósito). Prefira atraso progressivo, limites por origem e por dispositivo, e MFA — veja .

ATAQUES DE REDE E NEGAÇÃO DE SERVIÇO

Muitos protocolos da internet nasceram sem autenticação: quem está "no caminho" pode ler, alterar ou redirecionar o tráfego. Já a **negação de serviço** (DoS) ataca a **disponibilidade**; no formato distribuído (**DDoS**), o tráfego vem de milhares de origens — botnets, muitas vezes de dispositivos IoT, como a Mirai, que em 2016 derrubou o provedor de DNS Dyn. Defesas de rede em .

ATAQUE	POR QUE FUNCIONA	DEFESA (VER MÓDULO 09)
Sniffing	Tráfego sem criptografia é legível por quem está no caminho (Wi-Fi aberto, hub, porta espelhada)	TLS em tudo, VPN, Wi-Fi com WPA3 ou 802.1X
***Man-in-the-middle* (MITM)**	O adversário se coloca entre as partes e lê ou altera as mensagens	TLS com validação de certificado, HSTS
ARP spoofing	O ARP não tem autenticação: respostas falsas redirecionam o tráfego na rede local	Inspeção dinâmica de ARP, segmentação, 802.1X
Envenenamento de cache DNS	O resolvedor aceita uma resposta falsa e a entrega a todos os clientes	DNSSEC, resolvedores atualizados, DoT/DoH
DDoS volumétrico	Esgota a banda do enlace; a *amplificação/reflexão* multiplica o tráfego (DNS, NTP, memcached)	Absorção em CDN ou *scrubbing*, *anycast*, filtro antifalsificação (BCP 38)
DDoS de protocolo	Esgota tabelas de estado de firewalls e servidores (*SYN flood*)	*SYN cookies*, limites de conexão, equipamentos com estado robusto
DDoS de aplicação (camada 7)	Requisições aparentemente legítimas que consomem CPU e banco (HTTP flood, Slowloris)	WAF, *rate limiting*, cache, desafios, *autoscaling* com teto

02 **AMEAÇAS E ATAQUES** CONTINUAÇÃO

Exemplo: fator de amplificação: se um pedido falsificado de 60 bytes gera uma resposta de 3.000 bytes, o fator é 3.000 ÷ 60 = **50×**. Com 100 Mbit/s de pedidos, a vítima recebe cerca de 5 Gbit/s. O adversário "empresta" a banda de servidores abertos (resolvedores DNS, NTP) e falsifica o IP de origem; por isso o filtro antifalsificação na borda (BCP 38, RFC 2827) e o fechamento de serviços abertos importam.

AMEAÇAS INTERNAS, FÍSICAS E DE TERCEIROS

Ameaça interna

Três perfis: **malicioso** (age de propósito), **negligente** (erra ou burla controle) e **comprometido** (conta roubada). Controles: menor privilégio, separação de funções, desligamento imediato de acessos e monitoramento de comportamento (,).

Ameaça física e ambiental

Quem tem acesso físico ao equipamento anula muitos controles lógicos: perda de notebook, *tailgating* (seguir alguém na porta), USB deixado de isca. Também entram incêndio, energia e enchente. Controles: criptografia de disco, travas, crachás, *nobreak*, plano de recuperação.

Terceiros e cadeia de suprimentos

O adversário ataca quem você usa: fornecedores, bibliotecas e atualizações. SolarWinds (2020) e xz (2024) mostram o padrão; o DBIR 2026 aponta terceiros em 48% das violações. Controles: avaliação de fornecedores, SBOM, assinatura e verificação ().

CYBER KILL CHAIN: CADA FASE É UMA CHANCE DE INTERROMPER

A *Cyber Kill Chain* (Lockheed Martin, 2011) descreve a intrusão em **sete fases**. Seu valor didático é a ideia de que a defesa não precisa vencer em todas: **basta interromper uma** — e quanto mais cedo, mais barato. Seus limites: assume um ataque linear vindo de fora e diz pouco sobre credenciais legítimas, movimento lateral e cadeia de suprimentos, e por isso costuma ser usada junto com o ATT&CK.



As sete fases da Cyber Kill Chain. Em vermelho, o que o adversário faz; em verde, um controle que pode interromper a fase. Quanto mais à esquerda a interrupção, menor o dano e o custo.

MITRE ATT&CK: O VOCABULÁRIO COMUM

O **MITRE ATT&CK** é uma base de conhecimento pública, construída a partir de observações reais, que organiza o comportamento do adversário em **táticas** (o *porquê*: objetivos como acesso inicial ou persistência), **técnicas** e **subtécnicas** (o *como*; ex.: T1566 *Phishing* → T1566.001 anexo). Cada técnica se liga a **mitigações** (M####), **grupos** (G####) e **software** (S####) observados. Em outubro de 2026, a v20 reorganizou a matriz Enterprise: a tática *Defense Evasion* foi dividida em **Stealth** (TA0005, misturar-se ao ambiente) e **Defense Impairment** (TA0112, degradar as defesas), chegando a 15 táticas.

02 AMEAÇAS E ATAQUES

CONTINUAÇÃO

Reconnaissance
Reconhecimento
T1595 Varredura ativa
T1589 Dados de identidade
T1593 Busca em sites

Resource Development
Preparar recursos
T1583 Infraestrutura
T1586 Comprometer contas
T1588 Obter capacidades

Initial Access
Acesso inicial
T1566 Phishing
T1190 App exposto
T1078 Contas válidas

Execution
Execução
T1059 Scripts e comandos
T1204 Ação do usuário
T1047 WMI

Persistence
Persistência
T1053 Tarefa agendada
T1547 Execução ao iniciar
T1136 Criar conta

Privilege Escalation
Escalada de privilégio
T1068 Explorar falha local
T1548 Abuso de elevação
T1134 Manipular tokens

Stealth v20
Furtividade · TA0005
T1027 Ofuscação
T1036 Disfarce
T1070 Apagar indícios

Defense Impairment v20
Degradar defesas · TA0112
T1562 Prejudicar defesas
ex.: desligar EDR
ex.: cortar envio de logs

Credential Access
Acesso a credenciais
T1003 Dump de credenciais
T1110 Força bruta
T1558 Tickets Kerberos

Discovery
Descoberta
T1087 Descoberta de contas
T1046 Serviços de rede
T1083 Arquivos e pastas

Lateral Movement
Movimento lateral
T1021 Serviços remotos
T1550 Reuso de credencial
T1570 Ferramentas laterais

Collection
Coleta
T1005 Dados locais
T1560 Arquivar dados
T1213 Repositórios de info.

Command and Control
Comando e controle
T1071 Protocolos de app
T1573 Canal cifrado
T1090 Proxy

Exfiltration
Exfiltração
T1041 Via canal C2
T1567 Via serviço web
T1048 Outro protocolo

Impact
Impacto
T1486 Dados cifrados
T1490 Inibir recuperação
T1498 Negação de serviço

preparar e entrar · permanecer e se esconder · expandir o acesso · cumprir o objetivo

Matriz resumida do ATT&CK Enterprise (15 táticas, com exemplos de técnicas). Nomes de técnicas abreviados ou traduzidos; consulte o nome oficial e as subtécnicas no site. As duas táticas marcadas "v20" substituem a *Defense Evasion*.

Para que serve

- **Linguagem comum** entre SOC, caça a ameaças e gestão
- **Cobertura de detecção**: quais técnicas você enxerga e quais não? (o *ATT&CK Navigator* ajuda a pintar o mapa)
- *Threat-informed defense*: priorizar o que os grupos relevantes ao seu setor realmente fazem
- Planejar **emulação de adversário** e exercícios *purple team* ()

Cuidados

- Não é checklist: ter "verde" em uma técnica não prova que a detecção funciona — **teste**
- Técnica não é severidade: ela descreve comportamento, não risco (**p. 20**)
- Nomes e IDs mudam entre versões; cite sempre a versão consultada

PYRAMID OF PAIN E DIAMOND MODEL

A *Pyramid of Pain* (David Bianco, 2013) classifica os indicadores pelo **incômodo que causam ao adversário quando você os detecta**. Bloquear um hash é trivial de contornar; detectar um **comportamento** (TTPs) o obriga a mudar o jeito de operar. O *Diamond Model* (Caltagirone et al., 2013) lembra que todo evento de intrusão liga quatro vértices — **adversário, capacidade, infraestrutura e vítima** — e permite "pivotar" de um indicador para outro (a mesma infraestrutura aparece em outro ataque?).

NÍVEL (DA BASE AO TOPO)	TROCAR É...	EXEMPLO DE DETECÇÃO
Valores de hash	Trivial	Bloqueio por hash de arquivo (basta mudar um bit)
Endereços IP	Fácil	Listas de IPs maliciosos (trocam-se com facilidade)
Nomes de domínio	Simples	Bloqueio e *sinkhole* de DNS (custa registrar outro)
Artefatos de rede e de host	Incômodo	Padrões de *User-Agent*, chaves de registro, nomes de *mutex*
Ferramentas	Desafiador	Detecção da assinatura comportamental da ferramenta usada
TTPs (táticas, técnicas e procedimentos)	Difícil	Detecção do **modo de operar**: movimento lateral, uso de credenciais

02 AMEAÇAS E ATAQUES

CONTINUAÇÃO

LINHA DO TEMPO: CASOS QUE ENSINARAM A DEFENDER

2017 · WANNACRY
ransomware com propagação de worm via EternalBlue contra SMBv1 (MS17-010): centenas de milhares de máquinas em cerca de 150 países; paralisou serviços do NHS inglês. Um "kill switch" foi descoberto por pesquisador.

2017 · NOTPETYA
distribuído por uma atualização do software contábil ucraniano M.E.Doc (cadeia de suprimentos); destrutivo, disfarçado de ransomware.

2020 · SOLARWINDS
build do Orion comprometido; atualização adulterada (SUNBURST) enviada a cerca de 18.000 clientes, segundo a empresa; atribuída pelo governo dos EUA a ator russo.

2020 · STJ
ransomware (RansomEXX) derrubou sistemas do Superior Tribunal de Justiça por vários dias.

2021 · COLONIAL PIPELINE
ransomware DarkSide (RaaS); operação interrompida por precaução (CISA AA21-131A).

2021 · LOG4SHELL
CVE-2021-44228 no Log4j 2: consulta JNDI em mensagens de log levava a execução remota de código; CVSS 10,0; exemplo clássico de risco de dependência.

2024 · XZ/LIBLZMA
CVE-2024-3094: backdoor nas versões 5.6.0 e 5.6.1, descoberto por Andres Freund ao notar lentidão no SSH; fruto de engenharia social de longo prazo contra quem mantinha o projeto.

2024 · CROWDSTRIKE (NÃO FOI ATAQUE)
atualização de conteúdo defeituosa derrubou cerca de 8,5 milhões de máquinas Windows (estimativa da Microsoft): lembrete de que a **disponibilidade** também falha por erro interno.

EXEMPLO RESOLVIDO

Cenário. Uma analista do financeiro digita a senha em um site falso recebido por e-mail. Dois dias depois, alguém entra pela VPN (sem MFA), obtém credenciais de administrador, copia arquivos e cifra os servidores.

Mapeamento. Kill Chain: entrega → exploração (o usuário) → instalação → ações no objetivo. ATT&CK: *Initial Access* (T1566 *Phishing*) → *Initial Access* com T1078 *Valid Accounts* → *Credential Access* → *Lateral Movement* → *Exfiltration* → *Impact* (T1486).

Controles que interromperiam a cadeia, do mais cedo ao mais tarde. (1) **FIDO2/passkeys**: o site falso não consegue reaproveitar a prova criptográfica do domínio original; (2) **MFA na VPN** e alerta de login atípico; (3) **menor privilégio** e senha de administrador local única (LAPS); (4) **filtro de saída** e DLP para barrar a cópia; (5) **backup imutável** com restauração testada.

Para refletir. Qual desses controles é o mais barato? Qual interrompe mais cedo? Se só um pudesse ser implantado neste trimestre, qual você escolheria e por quê?

MAPA RÁPIDO: DA AMEAÇA AO MÓDULO DE DEFESA

AMEAÇA	PRIMEIRAS DEFESAS	ONDE ESTUDAR
Phishing e engenharia social	Treinamento, DMARC, MFA resistente a phishing, verificação por outro canal	,
Credenciais fracas ou vazadas	Hash lento, MFA, passkeys, detecção de abuso de contas	
Ransomware	Backup imutável, segmentação, EDR, menor privilégio, plano de resposta	, ,
Exploração de vulnerabilidades	Gestão de vulnerabilidades, *hardening*, correção rápida, WAF	p. 20,
Interceptação e MITM	TLS, HSTS, DNSSEC, validação de certificados	,
Negação de serviço (DDoS)	CDN, *rate limiting*, filtro antifalsificação, planejamento de capacidade	

02 AMEAÇAS E ATAQUES

CONTINUAÇÃO

AMEAÇA	PRIMEIRAS DEFESAS	ONDE ESTUDAR
Ameaça interna	Menor privilégio, separação de funções, monitoramento e desligamento de acessos	,
Cadeia de suprimentos	SBOM, assinatura e verificação de artefatos, avaliação de fornecedores	

PARA FIXAR

Conceitos

- Diferencie dupla e tripla extorsão e explique o papel dos corretores de acesso inicial.
- Por que a *Pyramid of Pain* coloca TTPs no topo e hashes na base?
- Qual a diferença entre *credential stuffing* e *password spraying*?

Aplicação

- Para o incidente do exemplo, escolha uma técnica do ATT&CK em cada tática e proponha uma detecção para cada uma.
- Calcule a banda recebida por uma vítima se 200 Mbit/s de pedidos falsificados tiverem fator de amplificação 40×.
- Monte um plano de backup 3-2-1-1-0 para um laboratório de universidade.

APROFUNDE-SE

Leituras e referências

- MITRE ATT&CK — MITRE: táticas, técnicas, grupos, mitigações e o Navigator.
- #StopRansomware — CISA: guias e alertas sobre ransomware, com listas de verificação.
- Alerta AA21-131A (DarkSide) — CISA/FBI, 2021: caso real com indicadores e mitigações.
- Data Breach Investigations Report — Verizon: estatísticas anuais de incidentes e violações.
- Cartilha de Segurança para Internet — CERT.br/NIC.br: golpes, códigos maliciosos e ataques, em português.

MÓDULO 03 · RISCOS

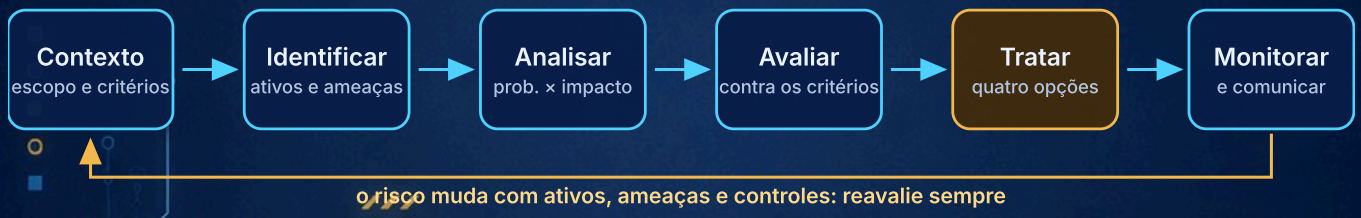
03 RISCOS E MODELAGEM DE AMEAÇAS

Como medir, priorizar e tratar riscos — e como descobrir ameaças ainda no projeto, antes do código.

Risco é o que transforma "segurança" em decisão: o que proteger primeiro, com quanto dinheiro e até que ponto aceitar o que sobra. Este módulo ensina a **estimar e tratar riscos**, a **priorizar vulnerabilidades** (CVSS, EPSS, KEV) e a **modelar ameaças** (DFD e STRIDE) ainda na fase de projeto.

GESTÃO DE RISCO: O CICLO

Um **risco** combina a **probabilidade** de uma ameaça explorar uma vulnerabilidade e o **impacto** resultante; na forma mais simples, *risco = probabilidade × impacto*. A **gestão de riscos** é o processo contínuo de identificar, analisar, avaliar e tratar esses riscos. Ela sustenta normas como a **ISO/IEC 27005** e a **ISO 31000**, e guias como o **NIST SP 800-30 Rev. 1** (avaliação de risco), ligado ao *Risk Management Framework* (NIST SP 800-37 Rev. 2).



Risco inerente × residual

Inerente é o risco antes de qualquer controle; **residual** é o que sobra depois deles. O objetivo não é zerar o residual, e sim levá-lo **abaixo do que a organização tolera**.

Apetite × tolerância

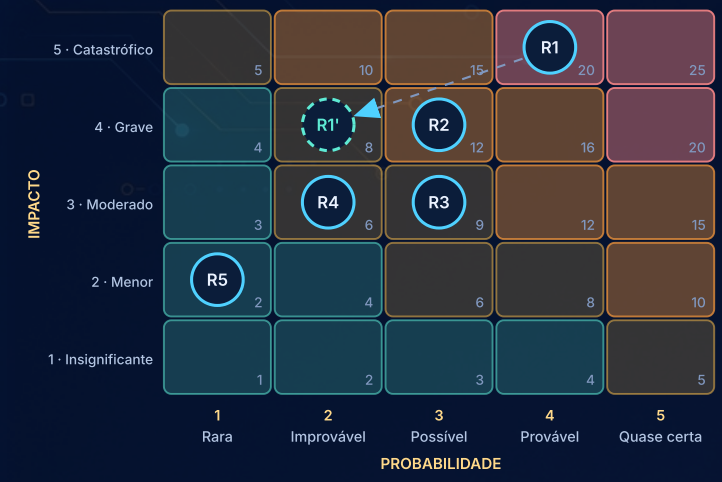
Apetite é o quanto de risco a organização aceita buscar para atingir seus objetivos; **tolerância** é o desvio máximo aceitável em torno disso. Ambos são decididos pela **gestão**, não pela equipe técnica.

ANÁLISE QUALITATIVA: A MATRIZ 5×5

Quando faltam dados históricos, probabilidade e impacto são classificados em **escalas ordinais** de 1 a 5 e multiplicados. O método é rápido e bom para comparar, mas **subjetivo**: duas pessoas pontuam diferente. Para reduzir o problema, defina cada nível por escrito — por exemplo, impacto 5 = parada superior a 3 dias ou vazamento de dados sensíveis em larga escala; probabilidade 5 = esperado mais de uma vez por ano.

03 RISCOS E MODELAGEM DE AMEAÇAS

CONTINUAÇÃO



REGISTRO DE RISCOS (EXEMPLO: PORTAL ACADÊMICO)

R1	Phishing a docentes leva à alteração de notas	P4 × I5 = 20 · crítico
R2	Ransomware no servidor de arquivos	P3 × I4 = 12 · alto
R3	Matrícula fora do ar (DDoS de aplicação)	P3 × I3 = 9 · médio
R4	Perda de notebook com dados de pesquisa	P2 × I3 = 6 · médio
R5	Pichação do site institucional	P1 × I2 = 2 · baixo
R1'	R1 residual, com FIDO2 e alertas (tracejado)	P2 × I4 = 8 · médio

Matriz de risco 5×5 (mapa de calor). O número no canto de cada célula é probabilidade × impacto. R1' mostra o **risco residual** de R1 depois de controles que reduzem a probabilidade e o impacto.

> **Atenção:** a matriz tem armadilhas conhecidas: multiplicar números ordinais não é rigoroso; um risco raro, mas catastrófico, some em uma célula amarela; e dois riscos com o mesmo nível podem exigir respostas muito diferentes. Use a matriz para **organizar a conversa**, não para decidir sozinha.

ANÁLISE QUANTITATIVA: SLE, ARO E ALE

Com estimativas monetárias, o risco vira uma **perda anual esperada**:

- **AV** (*Asset Value*): valor do ativo;
- **EF** (*Exposure Factor*): fração do valor perdida em um incidente, de 0 a 1;
- **SLE** (*Single Loss Expectancy*) = AV × EF: perda por ocorrência;
- **ARO** (*Annualized Rate of Occurrence*): ocorrências esperadas por ano;
- **ALE** (*Annualized Loss Expectancy*) = SLE × ARO: perda anual esperada.

Um controle compensa, em termos econômicos, se **(ALE antes − ALE depois) > custo anual do controle**. O retorno se mede pelo **ROSI** (*Return on Security Investment*) = (redução do ALE − custo) ÷ custo. O método **FAIR** (*Factor Analysis of Information Risk*, padrão Open FAIR) refina a ideia: separa **frequência** e **magnitude** da perda, usa estimativas calibradas em **faixas** (mínimo, mais provável, máximo) e simula milhares de cenários (Monte Carlo) para obter uma distribuição, não um número único.

EXEMPLO RESOLVIDO

Cenário. A base de matrículas (AV = R$ 2.000.000, somando recuperação, multas e perda de confiança) pode ser exposta por uma falha de injeção SQL. Em um vazamento, estima-se perder **EF = 25%** do valor: **SLE = 2.000.000 × 0,25 = R$ 500.000**. A equipe estima 1 ocorrência a cada 5 anos, ou seja, **ARO = 0,2**. Logo, **ALE = 500.000 × 0,2 = R$ 100.000 por ano**.

Controle. Revisão de código, SAST e WAF custam **R$ 40.000 por ano** e reduzem o ARO para 0,05 (1 a cada 20 anos): novo ALE = 500.000 × 0,05 = R$ 25.000. A redução é de **R$ 75.000**; o valor líquido é 75.000 − 40.000 = **R$ 35.000 por ano**; **ROSI = 35.000 ÷ 40.000 = 87,5%**.

Decisão e ressalvas. Em termos econômicos, o controle se paga. Mas são estimativas: use faixas, registre as hipóteses e compare com o apetite a risco. Além disso, uma obrigação legal (como a LGPD) pode exigir o controle **independentemente do ROSI**.

03 **RISCOS E MODELAGEM DE AMEAÇAS** CONTINUAÇÃO

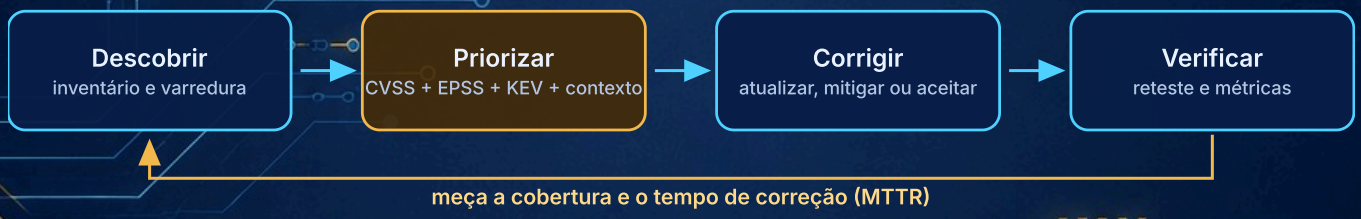
TRATAMENTO DO RISCO E REGISTRO DE RISCOS

OPÇÃO	O QUE É	EXEMPLO	QUANDO ESCOLHER
Mitigar (reduzir)	Aplicar controles que reduzem a probabilidade ou o impacto	MFA, correção de falhas, backup, segmentação	O custo do controle é menor que a redução do risco
Transferir (compartilhar)	Passar parte do impacto financeiro a terceiros	Seguro cibernético, cláusulas contratuais, serviço gerenciado	Impacto alto e probabilidade baixa; responsabilidade legal e reputação **não** se transferem
Evitar (eliminar)	Eliminar a atividade ou o ativo que gera o risco	Não coletar dado desnecessário; desligar sistema legado	O risco supera o benefício da atividade
Aceitar (reter)	Conviver com o risco de forma consciente e documentada	Risco baixo ou tratamento mais caro que a perda	Está dentro do apetite; tem dono, registro e revisão

Em resumo: o **registro de riscos** é o documento vivo da gestão. Campos mínimos: ID · ativo · ameaça · vulnerabilidade · probabilidade · impacto · nível · tratamento · dono · prazo · status · próxima revisão. Todo risco aceito precisa da **assinatura de quem tem autoridade para aceitá-lo**.

GESTÃO DE VULNERABILIDADES

Uma **vulnerabilidade** é uma fraqueza que pode ser explorada. Gerenciá-las é um **ciclo contínuo**, não um projeto com data de término. O volume é enorme — dezenas de milhares de CVEs por ano —, então o problema central é **priorizar**.

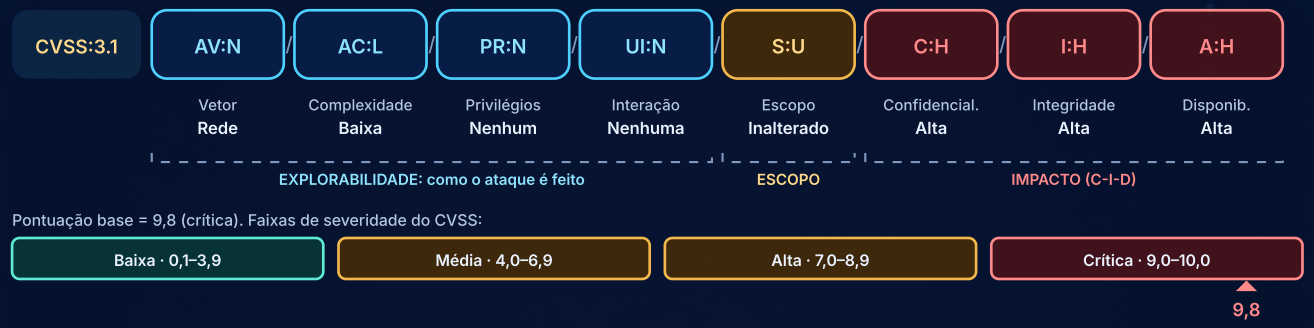


SIGLA	O QUE IDENTIFICA	MANTIDO POR	EXEMPLO
CVE	Uma vulnerabilidade específica em um produto	MITRE / CVE Program	CVE-2021-44228 (Log4Shell)
CWE	Um **tipo** de fraqueza de software ou hardware	MITRE	CWE-89 (injeção SQL)
CAPEC	Padrões de ataque: como uma fraqueza é explorada	MITRE	CAPEC-66 (injeção SQL)
CPE / NVD	Nome padronizado de produto e versão; base do NIST que enriquece CVEs com CVSS, CWE e CPE	NIST	nvd.nist.gov
CVSS	Gravidade técnica, de 0,0 a 10,0	FIRST	9,8 (crítica)
EPSS	Probabilidade de exploração nos próximos 30 dias, de 0 a 1	FIRST	0,91 = 91%
KEV	Catálogo de vulnerabilidades com exploração ativa confirmada	CISA	Está ou não está no catálogo

03 **RISCOS E MODELAGEM DE AMEAÇAS** CONTINUAÇÃO

CVSS: COMO LER UM VETOR

O **CVSS** (*Common Vulnerability Scoring System*, mantido pelo FIRST) descreve a **gravidade técnica** de uma vulnerabilidade com um **vetor** legível e uma nota de 0,0 a 10,0. A versão 3.1 tem três grupos: **Base** (propriedades intrínsecas), **Temporal** (maturidade do exploit, existência de correção) e **Ambiental** (importância do ativo no seu contexto). A **v4.0** (2023) renomeia o temporal para **Threat**, acrescenta os requisitos de ataque (*Attack Requirements*, AT), troca o *Scope* por impactos no sistema vulnerável (VC/VI/VA) e em sistemas subsequentes (SC/SI/SA) e inclui o grupo **Supplemental**.



Anatomia de um vetor CVSS 3.1. Cada par métrica:valor é uma pergunta sobre a vulnerabilidade. Este vetor (rede, baixa complexidade, sem privilégios nem interação, impacto alto em C, I e D) resulta em 9,8. O Log4Shell chega a 10,0 porque o escopo muda (S:C).

> **Atenção:** a nota **Base** mede severidade, **não risco**: ignora se há exploração real, se o serviço está exposto e quanto o ativo vale. Usar só o CVSS gera uma fila de "críticos" que ninguém consegue corrigir — e deixa passar o que realmente está sendo explorado.

Por isso somam-se sinais de contexto. O **EPSS** (FIRST) estima a probabilidade de exploração em 30 dias a partir de dados observados; o **KEV** (CISA) lista o que já está sendo explorado de fato. Juntos respondem à pergunta que o CVSS não responde: *"isso está sendo usado contra alguém agora?"*. O **SSVC** (CISA e Carnegie Mellon) vai além: é uma árvore de decisão que combina pontos como exploração, automatização, impacto técnico e impacto na missão, e termina em ações como acompanhar, atender ou agir.

VULNERABILIDADE	CVSS E EPSS	KEV, EXPOSIÇÃO E ATIVO	DECISÃO
A · execução remota em biblioteca interna	CVSS 9,8 · EPSS 0,02	Fora do KEV; rede interna isolada; ativo de baixo valor	P3: agendar no ciclo normal
B · falha de autenticação na VPN	CVSS 7,5 · EPSS 0,91	No KEV; exposta à internet; ativo crítico	P1: corrigir ou mitigar em 24 a 72 h
C · XSS no portal do aluno	CVSS 6,1 · EPSS 0,10	Fora do KEV; exposto; ativo médio	P2: corrigir em 15 a 30 dias

EXEMPLO RESOLVIDO

Leitura. B não tem a maior nota (A tem 9,8), mas é a mais urgente: exploração ativa (KEV), 91% de chance de exploração em 30 dias, borda da rede e ativo crítico. A, com a maior nota, fica por último: sem exploração conhecida e sem exposição. A ordem **B → C → A** inverte a ordem do CVSS.

Regra de bolso. Prioridade = exploração real (KEV, EPSS) + exposição + criticidade do ativo e, só então, a nota CVSS. Prazos são política de cada organização; como exemplo: explorada ativamente, em dias; crítica, 7 a 15 dias; alta, 30; média, 90.

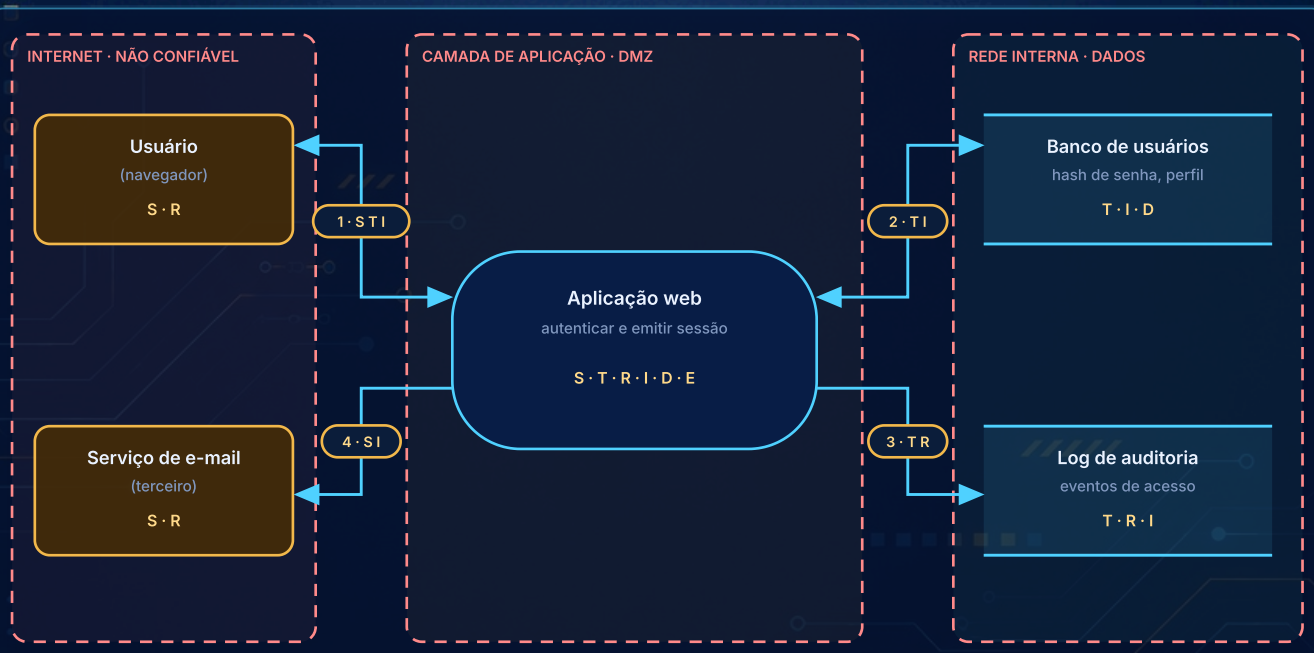
03 **RISCOS E MODELAGEM DE AMEAÇAS** CONTINUAÇÃO

MODELAGEM DE AMEAÇAS

Modelar ameaças é descobrir, ainda no projeto, **o que pode dar errado** e decidir o que fazer a respeito. É o controle mais barato do ciclo: corrigir uma falha de desenho em um diagrama custa horas; corrigi-la em produção custa semanas — e, às vezes, dados. Adam Shostack resume o método em **quatro perguntas**:

1. **O que estamos construindo?** Diagrama de fluxo de dados, ativos e fronteiras de confiança.
2. **O que pode dar errado?** STRIDE, árvores de ataque e casos de abuso.
3. **O que faremos a respeito?** Mitigar, transferir, evitar ou aceitar cada ameaça.
4. **Fizemos um bom trabalho?** Validar com testes, revisão por pares e métricas.

O **diagrama de fluxo de dados** (DFD) usa quatro elementos: **entidade externa** (quem está fora do seu controle), **processo** (código que transforma dados), **repositório** (onde os dados repousam) e **fluxo** (dados em trânsito). Sobre ele se desenham as **fronteiras de confiança**, linhas que separam níveis de confiança, e a regra de ouro é: **todo fluxo que cruza uma fronteira merece análise** — autenticação, validação, criptografia e registro.



DFD de um login web com fronteiras de confiança. As letras mostram as ameaças STRIDE aplicáveis a cada elemento (nas caixas) e a cada fluxo (nas pílulas numeradas): 1 credenciais e sessão, 2 consulta ao banco, 3 eventos de auditoria, 4 e-mail de redefinição de senha.

AMEAÇA	PROPRIEDADE VIOLADA	EXEMPLO NO LOGIN WEB	MITIGAÇÃO TÍPICA
Spoofing (falsificação de identidade)	Autenticidade	*Credential stuffing*; sessão roubada e reutilizada	MFA resistente a phishing, cookies `Secure; HttpOnly`, limite de tentativas
Tampering (adulteração)	Integridade	Alterar um parâmetro da requisição; alterar o banco ou o log	Validação no servidor, consultas parametrizadas, TLS, logs imutáveis

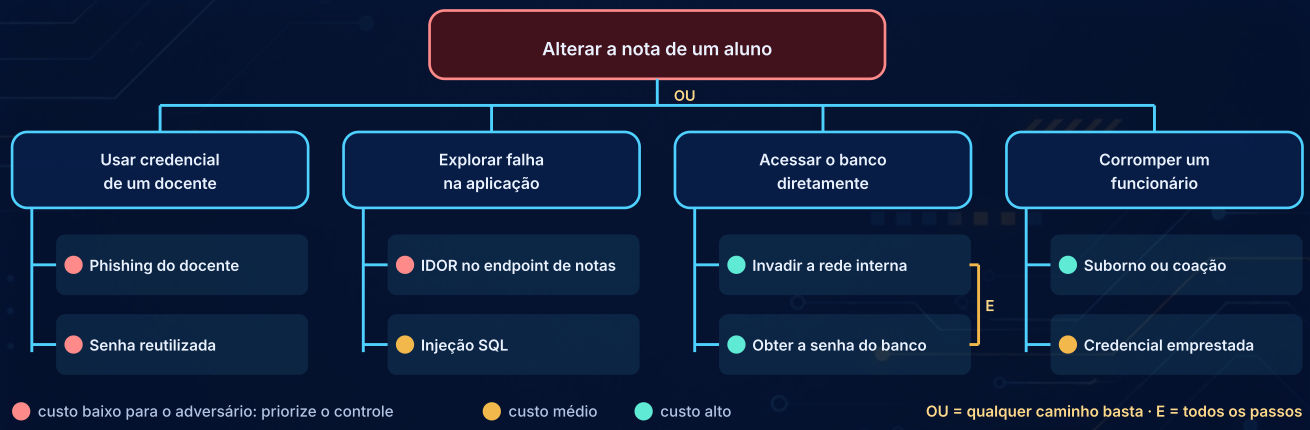
03 RISCOS E MODELAGEM DE AMEAÇAS — CONTINUAÇÃO

AMEAÇA	PROPRIEDADE VIOLADA	EXEMPLO NO LOGIN WEB	MITIGAÇÃO TÍPICA
Repudiation (repúdio)	Não repúdio	"Não fui eu que alterei a nota", sem registro confiável	Log de auditoria com identidade, hora (UTC) e integridade
Information disclosure (vazamento)	Confidencialidade	Erro que revela se o usuário existe; hash exposto em um *dump*	Mensagens genéricas, hash lento com sal, criptografia em repouso
Denial of service (negação de serviço)	Disponibilidade	Inundação de tentativas de login esgota o processo	*Rate limiting*, filas, limites por origem, *autoscaling* com teto
Elevation of privilege (elevação)	Autorização	Trocar `role=aluno` por `role=admin` e ser aceito	Autorização no servidor em cada operação, menor privilégio

STRIDE por elemento: nem toda ameaça se aplica a todo elemento do DFD. **Entidades externas**: S e R. **Processos**: as seis. **Repositórios**: T, I e D (e R, se guardam logs). **Fluxos**: T, I e D. As letras nas caixas e nas pílulas do diagrama mostram o que cada elemento pede.

ÁRVORES DE ATAQUE E OUTRAS ABORDAGENS

O STRIDE olha **cada elemento** do sistema; a **árvore de ataque** (Bruce Schneier, 1999) olha **o objetivo do adversário** e desce até os passos concretos. A raiz é o objetivo; os nós intermediários são caminhos alternativos (**OU**) ou passos obrigatórios em conjunto (**E**); as folhas recebem uma estimativa de **custo, habilidade ou probabilidade**. O ganho é prático: o caminho **mais barato** para o adversário é onde o controle rende mais.



Árvore de ataque: objetivo "alterar a nota de um aluno". O objetivo fica na raiz; cada ramo é um caminho alternativo (OU); o ramo do banco exige todos os passos (E). Os pontos vermelhos mostram os passos mais baratos para o adversário, onde o controle rende mais.

MÉTODO	FOCO	QUANDO USAR
Árvores de ataque (Schneier, 1999)	Objetivo do adversário na raiz; caminhos alternativos como ramos, com custo e probabilidade	Analisar um objetivo crítico (ex.: alterar notas)
PASTA	Processo de sete etapas orientado ao risco de negócio e à simulação de ataques	Quando há forte ligação com risco e negócio

03 RISCOS E MODELAGEM DE AMEAÇAS — CONTINUAÇÃO

MÉTODO	FOCO	QUANDO USAR
LINDDUN	Ameaças à privacidade: vinculação, identificação, não repúdio, detecção, divulgação, desconhecimento e não conformidade	Sistemas com dados pessoais (LGPD)
Casos de abuso (*abuse cases*)	Histórias de usuário "ao contrário": "como atacante, quero..."	Levantamento de requisitos de segurança
DREAD	Pontuação de dano, reprodutibilidade, explorabilidade, usuários afetados e descoberta	Obsoleto: notas subjetivas e inconsistentes; prefira risco e CVSS

Boa prática: trate o modelo como **artefato vivo**: guarde-o versionado junto ao código (por exemplo, com OWASP *Threat Dragon* ou *pytm*, que descreve o modelo como código), revise a cada mudança de arquitetura ou integração e ligue cada ameaça a um **requisito** e a um **teste**. O *Threat Modeling Manifesto* (2020) valoriza **pessoas e colaboração** acima de processos e ferramentas, e **fazer** a modelagem acima de falar sobre ela.



DICA DA CORUJA

comece pequeno: um fluxo por vez (login, pagamento, redefinição de senha). Um DFD que cabe em uma folha e gera dez perguntas incômodas já valeu a pena; o perfeito, que ninguém termina, não protege nada.

PARA FIXAR

Conceitos

- Diferencie apetite e tolerância ao risco, e risco inerente de residual.
- Por que o CVSS Base não basta para priorizar correções? O que EPSS e KEV acrescentam?
- Por que "todo fluxo que cruza uma fronteira de confiança merece análise"?

Aplicação

- Uma loja virtual tem AV = R$ 800.000, EF = 40% e ARO = 0,5. Calcule SLE e ALE; um controle de R$ 60.000 por ano reduz o ARO para 0,1. Vale a pena?
- Desenhe o DFD do fluxo "esqueci minha senha" e aplique STRIDE a cada elemento.
- Plote em uma matriz 5×5 quatro riscos do seu laboratório e proponha o tratamento de cada um.

APROFUNDE-SE

Leituras e referências

- NIST SP 800-30 Rev. 1 — NIST: guia para conduzir avaliações de risco.
- CVSS — FIRST: especificação, calculadoras e guia do usuário das versões 3.1 e 4.0.
- EPSS — FIRST: modelo, dados diários e documentação.
- Known Exploited Vulnerabilities Catalog — CISA: lista de vulnerabilidades com exploração ativa.
- Threat Modeling Manifesto — valores e princípios da modelagem de ameaças.
- OWASP Threat Dragon — OWASP: ferramenta de código aberto para diagramar e modelar ameaças.

MÓDULO 04 · GOVERNANÇA

04 NORMAS, LEIS E CONFORMIDADE

Frameworks, padrões e leis que dão estrutura à segurança — e a diferença entre estar conforme e estar seguro.

Segurança sem governança vira esforço individual: normas e leis dão **estrutura, linguagem comum e obrigações** ao que a equipe técnica faz. Este módulo mostra como as organizações governam a segurança da informação, os principais *frameworks* (ISO/IEC 27001, NIST CSF 2.0, CIS Controls, PCI DSS), o arcabouço legal brasileiro e uma distinção essencial: **estar em conformidade não é estar seguro**.

GOVERNANÇA, GESTÃO E OPERAÇÃO

Três níveis se complementam. A **governança** define direção e responsabilidade: a alta direção decide o apetite a risco, aprova a política e cobra resultados. A **gestão** planeja, organiza e mede: o CISO, o comitê de segurança e os donos de ativos transformam a direção em programa, orçamento e indicadores. A **operação** executa e monitora: TI, desenvolvimento, SOC e suporte aplicam os controles no dia a dia. Sem governança, ninguém é cobrado; sem gestão, não há priorização; sem operação, só existe papel.

DOCUMENTO	NATUREZA	RESPONDE A	EXEMPLO
Política	Obrigatória; curta e estável; aprovada pela direção	O quê e por quê	Política de Segurança da Informação: princípios, papéis e sanções
Norma	Obrigatória; requisitos objetivos e verificáveis	Quanto e quais	Norma de senhas e de MFA; norma de classificação da informação
Procedimento	Obrigatório; passo a passo operacional	Como	Revogação de acessos no desligamento de um funcionário
Diretriz (guia)	Recomendada; boas práticas e orientação	Como fazer melhor	Guia de trabalho remoto seguro; guia de desenvolvimento seguro



DICA DA CORUJA

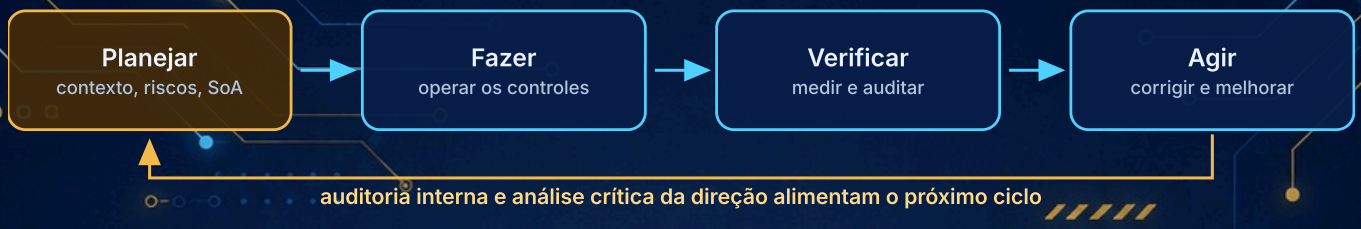
uma política que ninguém consegue cumprir é pior do que nenhuma: vira "letra morta" e ensina a equipe a ignorar regras. Escreva política **curta**, norma **verificável** e procedimento **testado por quem vai usá-lo**; revise tudo uma vez por ano e depois de cada incidente relevante.

ISO/IEC 27001:2022 E A FAMÍLIA 27000

A **ISO/IEC 27001** especifica os requisitos de um **Sistema de Gestão de Segurança da Informação** (SGSI, *ISMS*). Não é uma lista de ferramentas: é um **sistema de gestão** que decide o que proteger, avalia riscos, escolhe controles, mede e melhora continuamente — o ciclo **PDCA** (*Plan-Do-Check-Act*). É a norma **certificável** do tema: um organismo de certificação acreditado audita em duas etapas (documentação e implementação), emite um certificado com validade de três anos e realiza auditorias de manutenção anuais. A transição da edição de 2013 para a de 2022 terminou em **31 de outubro de 2025**.

04 NORMAS, LEIS E CONFORMIDADE

CONTINUAÇÃO



CLÁUSULA	PDCA	O QUE EXIGE
4 · Contexto da organização	Planejar	Entender o contexto e as partes interessadas; definir o **escopo** do SGSI
5 · Liderança	Planejar	Compromisso da direção; **política** de segurança; papéis e responsabilidades
6 · Planejamento	Planejar	Avaliar e tratar **riscos**; produzir a **Declaração de Aplicabilidade**; fixar objetivos
7 · Apoio	Fazer	Recursos, competência, conscientização, comunicação e informação documentada
8 · Operação	Fazer	Executar o plano de tratamento de riscos e as avaliações de risco planejadas
9 · Avaliação de desempenho	Verificar	Monitoramento e medição, **auditoria interna** e análise crítica pela direção
10 · Melhoria	Agir	Tratar não conformidades, executar ações corretivas e melhorar continuamente

Em resumo: a **Declaração de Aplicabilidade** (*Statement of Applicability*, SoA) lista cada controle do Anexo A, diz se é aplicável, justifica inclusões e exclusões e informa o estado de implementação. É o documento que o auditor lê primeiro, e ela só faz sentido se nascer da **avaliação de riscos** — controle não se escolhe por moda.

TEMA DO ANEXO A	Nº	COBRE	EXEMPLOS
Organizacionais (A.5)	37	Políticas, papéis, ativos, acesso, fornecedores, incidentes, continuidade, requisitos legais	Inteligência de ameaças; segurança de serviços em nuvem; prontidão de TIC para continuidade
Pessoas (A.6)	8	Antes, durante e depois do vínculo com a organização	Triagem; termos de contratação; conscientização; trabalho remoto; reporte de eventos
Físicos (A.7)	14	Perímetros, áreas seguras, equipamentos e mídias	Monitoramento da segurança física; mesa e tela limpas; descarte seguro
Tecnológicos (A.8)	34	Dispositivos, identidades, redes, criptografia e desenvolvimento	Gestão de configuração; mascaramento de dados; DLP; monitoramento; filtragem web; codificação segura

A edição de 2022 reduziu os controles de 114 (em 14 domínios) para **93 em 4 temas** e acrescentou **11 novos**: inteligência de ameaças, segurança de nuvem, prontidão de TIC para continuidade, monitoramento da segurança física, gestão de configuração, exclusão de informação, mascaramento de dados, prevenção de vazamento de dados, monitoramento de atividades, filtragem web e codificação segura. Em volta dela orbita uma **família**: a **ISO/IEC 27002** (orientação de implementação dos controles), a **27005** (riscos), a **27017** e a **27018** (nuvem e dados pessoais em nuvem pública), a **27701** (extensão de privacidade), a **27035** (incidentes) e a **ISO 22301** (continuidade de negócios).

04 NORMAS, LEIS E CONFORMIDADE — CONTINUAÇÃO

NIST CSF 2.0, SP 800-53 E CIS CONTROLS

O **NIST Cybersecurity Framework 2.0** (fevereiro de 2024) é um vocabulário de **resultados** em seis funções, com 22 categorias e 106 subcategorias. Não é certificável nem prescreve ferramentas: ajuda a descrever o que se quer alcançar e a conversar com a diretoria. A novidade é a função **Govern**, que coloca estratégia, papéis e gestão de riscos no centro. Duas ideias o tornam prático: os **Perfis** (*Profiles*: situação atual × situação-alvo, com o plano para fechar a diferença) e os **Níveis** (*Tiers*: parcial, ciente de risco, repetível e adaptativo).

GV · GOVERN · GOVERNAR
Estratégia, papéis, políticas, gestão de riscos e da cadeia de suprimentos.

ID · IDENTIFY · IDENTIFICAR
Ativos, riscos e oportunidades de melhoria que a organização precisa entender.

PR · PROTECT · PROTEGER
Salvaguardas: identidade e acesso, treinamento, segurança de dados e de plataformas.

DE · DETECT · DETECTAR
Monitoramento contínuo e análise de eventos adversos para achar ataques.

RS · RESPOND · RESPONDER
Gestão, análise, comunicação e mitigação dos incidentes detectados.

RC · RECOVER · RECUPERAR
Restaurar ativos e operações afetados e comunicar durante a recuperação.

No nível dos **controles**, o **NIST SP 800-53 Rev. 5** é o catálogo mais granular (20 famílias, como AC — controle de acesso, AU — auditoria e IR — resposta a incidentes), base de autorizações do governo dos EUA; o **SP 800-171** protege informações não classificadas controladas (CUI) em sistemas de fornecedores. Os **CIS Controls v8.1** (junho de 2024) trazem **18 controles** priorizados com base em dados de ataques reais, em três **Grupos de Implementação**: IG1 (higiene cibernética essencial, para equipes pequenas), IG2 e IG3 (organizações maiores e mais expostas). Os **CIS Benchmarks** completam o quadro com configurações seguras por produto (sistemas operacionais, nuvem, navegadores).

COMPARANDO FRAMEWORKS E ESCOLHENDO POR ONDE COMEÇAR



Mapa dos frameworks: cada um responde a uma pergunta diferente. Eles se complementam, não competem: obrigações legais definem o piso; o CSF organiza resultados; a ISO 27001 sustenta o sistema de gestão; os catálogos detalham os controles; os modelos de maturidade medem a evolução.

04 NORMAS, LEIS E CONFORMIDADE

CONTINUAÇÃO

FRAMEWORK	FINALIDADE	CERTIFICÁVEL?	QUANDO USAR
ISO/IEC 27001:2022	Requisitos de um SGSI e controles do Anexo A (93)	Sim, por organismo acreditado	Demonstrar gestão madura a clientes e reguladores
NIST CSF 2.0	Resultados em seis funções; perfis e níveis	Não (autoavaliação)	Estruturar o programa e falar com a diretoria
NIST SP 800-53 Rev. 5	Catálogo detalhado de controles (20 famílias)	Não; base de autorizações do governo dos EUA	Alta granularidade; sistemas governamentais
CIS Controls v8.1	18 controles priorizados; grupos IG1 a IG3	Não	Começar pelo essencial com orçamento limitado
PCI DSS v4.0.1	12 requisitos para dados de cartões de pagamento	Validação exigida por contrato	Quem armazena, processa ou transmite dados de cartão
SOC 2 (AICPA)	Relatório de auditor independente sobre os controles de um serviço	Atestação (relatório Tipo I ou II)	Fornecedores de SaaS que precisam provar controles

SOC 2 e PCI DSS em uma linha: o **SOC 2** avalia controles segundo cinco critérios de confiança — segurança (obrigatório), disponibilidade, integridade de processamento, confidencialidade e privacidade; o **Tipo I** atesta o desenho em uma data e o **Tipo II** atesta a eficácia ao longo de um período. O **PCI DSS** tem 12 requisitos; os requisitos "futuros" da versão 4.0 tornaram-se obrigatórios em 31 de março de 2025.

1 Comece pela obrigação
Leis (LGPD), regulação do setor e cláusulas de contrato definem o **piso inegociável**.

2 Estruture com resultados
Use o CSF 2.0 para descrever a situação **atual e a alvo** e comunicar com a gestão.

3 Escolha o catálogo de controles
CIS IG1 para começar; ISO/IEC 27002 ou NIST SP 800-53 para detalhar.

4 Prove e meça
ISO 27001 ou SOC 2 para **demonstrar a terceiros**; SAMM, BSIMM ou Tiers para medir a maturidade.

Maturidade: o **CMMI** descreve níveis de maturidade de processos; o **OWASP SAMM v2** é um modelo *prescritivo* de segurança de software (5 funções de negócio, 15 práticas, 3 níveis de maturidade); o **BSIMM** é *descritivo*: mede o que dezenas de empresas realmente fazem. Use-os para comparar-se e planejar, não para colecionar notas.

BRASIL: O QUE A LEI E OS REGULADORES EXIGEM

NORMA	TRATA DE	O QUE EXIGE EM SEGURANÇA
LGPD · Lei nº 13.709/2018	Tratamento de dados pessoais	Segurança como princípio (art. 6º, VII); medidas técnicas e administrativas (arts. 46 e 47); comunicação de incidentes (art. 48); sanções (art. 52)
Resolução CD/ANPD nº 15/2024	Comunicação de incidente de segurança	Comunicar a ANPD e os titulares em até **3 dias úteis** quando houver risco ou dano relevante; manter o registro por, no mínimo, 5 anos
Marco Civil · Lei nº 12.965/2014	Direitos e deveres na internet	Guarda de registros de conexão por 1 ano (art. 13) e de acesso a aplicações por 6 meses (art. 15), para quem se enquadra

04 NORMAS, LEIS E CONFORMIDADE

CONTINUAÇÃO

NORMA	TRATA DE	O QUE EXIGE EM SEGURANÇA
Código Penal, art. 154-A (Leis nº 12.737/2012 e 14.155/2021)	Invasão de dispositivo informático	Crime: reclusão de 1 a 4 anos e multa; 2 a 5 anos nas hipóteses do §3º; fraude eletrônica (art. 171, §2º-A): 4 a 8 anos
Resoluções CMN nº 4.893/2021 e BCB nº 85/2021	Segurança cibernética no setor financeiro	Política de segurança cibernética, plano de resposta a incidentes e requisitos para contratar serviços em nuvem e terceiros

O Decreto nº 11.856/2023 instituiu a **Política Nacional de Cibersegurança** (PNCiber). Na prática do dia a dia, o **CERT.br/NIC.br** (notificação e orientação; autor da *Cartilha de Segurança para Internet*) e o **CTIR Gov** (resposta a incidentes do governo federal) são as referências de coordenação. No meio acadêmico, vale conhecer também a **RNP**, que mantém o seu próprio centro de resposta.



Atores da LGPD e como se relacionam. O titular exerce direitos perante o controlador; o controlador instrui o operador e comunica incidentes; o encarregado é o canal de comunicação; a ANPD regula, fiscaliza e sanciona.

Na linguagem da LGPD, controlador e operador são os **agentes de tratamento**. O controlador responde pelas decisões e pelo cumprimento da lei; o operador, pelas instruções recebidas e pelas medidas de segurança. Bases legais, direitos do titular, relatório de impacto e anonimização são detalhados em ; a resposta a incidentes com dados pessoais, em . Fora do Brasil, três regimes aparecem com frequência em contratos e questionários:

NORMA	ESCOPO	PONTOS DE ATENÇÃO
GDPR · Regulamento (UE) 2016/679	Proteção de dados pessoais na UE; alcança quem oferece bens ou serviços a pessoas na UE	Multas de até € 20 milhões ou 4% do faturamento global; notificação à autoridade em até 72 h
NIS2 · Diretiva (UE) 2022/2555	Segurança de redes e sistemas de entidades essenciais e importantes	Gestão de riscos; notificação de incidentes significativos (alerta inicial em 24 h e notificação em 72 h)
CRA · Regulamento (UE) 2024/2847	Requisitos de segurança para produtos com elementos digitais	Em vigor desde dez/2024; notificação de vulnerabilidades exploradas a partir de set/2026 e obrigações principais a partir de dez/2027, segundo o calendário publicado

04 NORMAS, LEIS E CONFORMIDADE

CONTINUAÇÃO

Atenção: este guia é material de estudo, **não aconselhamento jurídico**. Prazos e multas mudam; a interpretação de uma lei em um caso concreto cabe à assessoria jurídica e ao encarregado.

CONFORMIDADE NÃO É SEGURANÇA

Conformidade

- Responde a **requisitos externos** (lei, norma, contrato)
- Olha o **passado**: auditoria por amostragem, em um instante
- É binária: está ou não está conforme
- Produz **evidências**: políticas, registros, relatórios

Segurança

- Responde a **adversários e riscos reais**
- Olha o **presente e o futuro**: detecção e resposta contínuas
- É gradual: sempre dá para melhorar, e nada é 100%
- Produz **resultados**: menos incidentes, detecção mais rápida

A **conformidade é o piso, não o teto**: cumprir um requisito de "ter MFA" não diz se ele cobre as contas privilegiadas nem se resiste a *phishing*. O vício a evitar é o *checkbox compliance*, marcar caixinhas para passar na auditoria. Trate a auditoria como um **teste do sistema**: a **interna** (de primeira parte) corrige antes que apareça lá fora; a de **segunda parte** é a que o cliente faz no fornecedor; a de **terceira parte** (certificação ou relatório independente) dá confiança a quem não pode auditar. Quando um requisito não puder ser cumprido, use **controle compensatório** documentado; e gerencie **exceções** com dono, justificativa, risco aceito, prazo e data de revisão — exceção sem prazo vira regra.

INDICADOR	TIPO	O QUE MOSTRA
% de ativos críticos com EDR e inventário atualizado	KPI	Cobertura dos controles essenciais
Tempo mediano de correção de vulnerabilidades críticas	KPI	Eficiência da gestão de vulnerabilidades
% de contas privilegiadas com MFA resistente a phishing	KPI	Proteção das identidades de maior risco
Tempo médio de detecção e de resposta (MTTD e MTTR)	KPI	Maturidade do monitoramento e da resposta
Vulnerabilidades do KEV ainda abertas	KRI	Exposição a ataques em curso
Exceções vencidas e riscos aceitos sem revisão	KRI	Governança frágil e dívida de segurança

Em resumo: **KPI** (*Key Performance Indicator*) mede o desempenho de um controle; **KRI** (*Key Risk Indicator*) avisa que o risco está subindo. Bons indicadores são **mensuráveis, comparáveis no tempo e ligados a uma decisão**: se ninguém age quando o número piora, ele é decoração.

04 NORMAS, LEIS E CONFORMIDADE

CONTINUAÇÃO

ESTUDO DE CASO

Cenário. Uma startup de provas online (SaaS) fecha contrato com uma universidade brasileira. Guarda notas e dados cadastrais de alunos, alguns adolescentes (dados de crianças e adolescentes pedem cuidado adicional, art. 14 da LGPD). O contrato prevê **questionário de segurança** e **aviso de incidentes em 48 horas**; em breve, um cliente europeu pedirá certificação.

Papéis. A universidade é **controladora**; a startup é **operadora**, segue as instruções do contrato e responde pela segurança do que processa. Quem comunica à ANPD e aos titulares é a controladora, então o contrato precisa obrigar a operadora a avisar **rápido**.

Roteiro em quatro fases. (1) **Obrigações**: contrato de tratamento, inventário de dados, encarregado e plano de resposta que caiba nas 48 h do contrato e nos 3 dias úteis da ANPD. (2) **Controles essenciais**: CIS IG1 — inventário, MFA, backup, correção de falhas, logs. (3) **Programa**: CSF 2.0 com perfil atual e alvo. (4) **Prova a terceiros**: SOC 2 (Tipo I e depois II) ou ISO/IEC 27001, sempre com evidência de que os controles **funcionam**, não só existem.

PARA FIXAR

Conceitos

- Diferencie política, norma, procedimento e diretriz com um exemplo de cada.
- O que é a Declaração de Aplicabilidade e por que o auditor a lê primeiro?
- Por que "estar em conformidade" não implica "estar seguro"?

Aplicação

- Uma clínica com 20 funcionários guarda prontuários. Quais obrigações brasileiras se aplicam e por onde você começaria (CIS IG1, CSF, ISO 27001)?
- Monte um quadro com cinco indicadores (três KPIs e dois KRIs) para um programa de gestão de vulnerabilidades.
- Um vazamento de dados de alunos foi descoberto na segunda-feira. Que prazos correm e quem precisa ser notificado?

APROFUNDE-SE

Leituras e referências

- ISO/IEC 27001 — ISO: página oficial da norma e de seu histórico de edições.
- NIST Cybersecurity Framework — NIST: CSF 2.0, guias rápidos e exemplos de implementação.
- CIS Critical Security Controls — CIS: controles, grupos de implementação e mapeamentos.
- Lei nº 13.709/2018 (LGPD) — Planalto: texto integral e atualizado.
- Autoridade Nacional de Proteção de Dados — gov.br: regulamentos, guias e a Resolução CD/ANPD nº 15/2024.
- PCI Security Standards Council — PCI SSC: padrões e documentos de apoio ao PCI DSS.

REFERÊNCIA

GLOSSÁRIO TÉCNICO

Consulta rápida a todos os termos usados neste guia — ótima para revisar antes das provas e dos projetos.

A

AAA. Autenticação, Autorização e Accounting (contabilização/auditoria): provar quem é, decidir o que pode fazer e registrar o que fez. **p. 5**

Agente de ameaça (threat actor). Pessoa, grupo ou entidade que materializa uma ameaça: cibercriminoso, insider, hacktivista, Estado, ou mesmo um erro humano. **p. 5**

AiTM (adversary-in-the-middle). Proxy de phishing que se coloca entre a vítima e o site real, capturando senha e cookie de sessão, inclusive após o MFA tradicional. **p. 11**

ALE (Annualized Loss Expectancy). Perda anual esperada: SLE multiplicado pelo ARO; base para comparar o custo de controles. **p. 20**

Ameaça (threat). Causa potencial de um incidente indesejado que pode resultar em dano ao ativo; pode ser humana, técnica ou ambiental. **p. 5**

Ameaça interna (insider threat). Risco originado por quem já tem acesso legítimo: pode ser malicioso, negligente ou ter a conta comprometida por terceiros. **p. 11**

Amplificação e reflexão. Técnica de DDoS que usa servidores abertos para responder com muito mais dados do que o pedido falsificado, em direção à vítima. **p. 11**

Análise qualitativa. Avaliação de risco em escalas ordinais (baixo, médio, alto; 1 a 5), útil quando faltam dados, mas subjetiva. **p. 20**

Análise quantitativa. Avaliação de risco em valores monetários e frequências, como SLE, ARO e ALE, ou modelos como FAIR. **p. 20**

Anexo A (ISO 27001:2022). Catálogo de 93 controles em quatro temas: organizacionais, pessoas, físicos e tecnológicos. **p. 27**

ANPD. Autoridade Nacional de Proteção de Dados: órgão que regula, fiscaliza e aplica sanções previstas na LGPD. **p. 27**

Apetite a risco. Quantidade e tipo de risco que a organização aceita buscar para cumprir seus objetivos. **p. 20**

APT (Advanced Persistent Threat). Ameaça persistente avançada: adversário bem financiado, em geral ligado a Estados, que mantém acesso discreto por longos períodos para espionar ou sabotar. **p. 11**

ARO (Annualized Rate of Occurrence). Número esperado de ocorrências do evento por ano; uma vez a cada cinco anos equivale a 0,2. **p. 20**

ARP spoofing. Envio de respostas ARP falsas para associar o endereço do atacante ao de outro host e desviar o tráfego na rede local. **p. 11**

Árvore de ataque. Diagrama com o objetivo do adversário na raiz e formas alternativas de alcançá-lo como ramos, com custo e probabilidade. **p. 20**

Ativo. Qualquer coisa que tenha valor para a organização e precise de proteção: dados, sistemas, pessoas, reputação, infraestrutura, propriedade intelectual. **p. 5**

Auditoria de primeira, segunda e terceira parte. Interna (a própria organização), do cliente sobre o fornecedor, e externa independente (certificação ou relatório). **p. 27**

Autenticidade. Garantia de que a origem de um dado ou de uma entidade é realmente a declarada. **p. 5**

AV (Asset Value). Valor do ativo, incluindo custo de recuperação, perda de receita, multas e impacto reputacional. **p. 20**

B

BCP 38 (RFC 2827). Boa prática de filtro de entrada (ingress filtering) que impede a saída de pacotes com IP de origem falsificado, reduzindo reflexão. **p. 11**

Beaconing. Comunicação periódica e regular que um sistema comprometido faz com o servidor C2; o padrão de tempo ajuda a detectá-la. **p. 11**

BEC (Business Email Compromise). Fraude que se passa por executivo ou fornecedor por e-mail para desviar pagamentos ou obter dados sensíveis. **p. 11**

Botnet. Rede de dispositivos infectados controlados remotamente por um servidor de comando e controle (C2), usada em DDoS, spam e fraudes. **p. 11**

BSIMM. Building Security In Maturity Model: modelo descritivo que mede o que organizações reais fazem em segurança de software. **p. 27**

C

CAPEC. Common Attack Pattern Enumeration and Classification: catálogo de padrões de ataque usados para explorar fraquezas. **p. 20**

Caso de abuso (abuse case). Descrição de como um atacante poderia usar uma funcionalidade de forma maliciosa; ajuda a derivar requisitos de segurança. **p. 20**

CERT.br. Centro de estudos, resposta e tratamento de incidentes de segurança no Brasil, mantido pelo NIC.br; autor da Cartilha de Segurança para Internet. **p. 27**

Checkbox compliance. Conformidade de fachada: cumprir requisitos apenas para passar em auditorias, sem reduzir o risco real. **p. 27**

Cibersegurança. Subconjunto da SI voltado a sistemas, redes e dados no meio digital; trata de ameaças que exploram computadores, software e a internet. **p. 5**

CIS Benchmarks. Guias de configuração segura por produto, mantidos pelo Center for Internet Security. **p. 27**

CIS Controls. Conjunto priorizado de 18 controles (v8.1) para defesa cibernética, com Grupos de Implementação IG1, IG2 e IG3. **p. 27**

— GLOSSÁRIO TÉCNICO

CONTINUAÇÃO

CISO. Chief Information Security Officer: executivo responsável pela estratégia e gestão de segurança da informação da organização. **p. 5**

CMMI. Modelo de maturidade de processos organizacionais, com níveis de capacidade. **p. 27**

COBIT. Framework da ISACA para governança e gestão de TI corporativa. **p. 27**

Comando e controle (C2). Infraestrutura pela qual o atacante envia ordens e recebe dados dos sistemas comprometidos. **p. 11**

Confidencialidade. Propriedade de que a informação só seja acessível a quem está autorizado; violada por vazamento ou acesso indevido. **p. 5**

Controlador. Agente de tratamento a quem competem as decisões sobre o tratamento de dados pessoais (LGPD). **p. 27**

Controle (contramedida). Medida que modifica o risco: política, procedimento, tecnologia ou prática que previne, detecta, corrige ou dissuade. **p. 5**

Controle compensatório. Controle alternativo, documentado, que oferece proteção equivalente quando o requisito original não pode ser cumprido. **p. 27**

Corretor de acesso inicial (IAB). Criminoso que obtém e vende acessos a redes corporativas (credenciais, VPN, RDP) a operadores de ransomware. **p. 11**

CPE. Common Platform Enumeration: esquema de nomes padronizados para produtos e versões, usado pelo NVD. **p. 20**

CRA (Cyber Resilience Act). Regulamento (UE) 2024/2847 com requisitos de segurança para produtos com elementos digitais, em vigor desde dezembro de 2024. **p. 27**

Credential stuffing. Uso automatizado de pares usuário/senha vazados de um serviço para tentar entrar em outros, aproveitando a reutilização de senhas. **p. 11**

CTIR Gov. Centro de Tratamento e Resposta a Incidentes Cibernéticos de Governo, responsável pela coordenação de resposta na administração pública federal. **p. 27**

CVE. Common Vulnerabilities and Exposures: identificador único de uma vulnerabilidade pública, no formato CVE-ano-número. **p. 20**

CVSS. Common Vulnerability Scoring System: padrão do FIRST que mede a gravidade técnica de vulnerabilidades em escala de 0,0 a 10,0. **p. 20**

CWE. Common Weakness Enumeration: catálogo de tipos de fraqueza de software e hardware (por exemplo CWE-79, XSS). **p. 20**

Cyber Kill Chain. Modelo da Lockheed Martin (2011) com sete fases de uma intrusão: reconhecimento, armamento, entrega, exploração, instalação, C2 e ações no objetivo. **p. 11**

D

Declaração de Aplicabilidade (SoA). Documento da ISO 27001 que lista os controles do Anexo A, indica se se aplicam, justifica exclusões e mostra o estado de implementação. **p. 27**

Deepfake. Mídia sintética (voz, imagem ou vídeo) gerada por IA que imita uma pessoa real; usada em fraudes e golpes de falsa identidade. **p. 11**

Defesa em profundidade. Estratégia de combinar camadas independentes de controles (pessoas, física, rede, host, aplicação, dados) para que a falha de uma não comprometa tudo. **p. 5**

DFD (Data Flow Diagram). Diagrama de fluxo de dados com entidades externas, processos, repositórios, fluxos e fronteiras de confiança. **p. 20**

Diamond Model. Modelo de análise de intrusão que relaciona quatro vértices: adversário, capacidade, infraestrutura e vítima. **p. 11**

Diretriz (guideline). Orientação recomendada, não obrigatória, com boas práticas para atingir o objetivo de uma política ou norma. **p. 27**

Disponibilidade. Propriedade de que sistemas e dados estejam acessíveis quando necessários a quem tem direito; atacada por DoS, ransomware ou falhas. **p. 5**

DoS e DDoS. Negação de serviço: esgota recursos para tornar um serviço indisponível; no DDoS, o ataque vem de muitas origens simultâneas. **p. 11**

DREAD. Modelo antigo de pontuação (dano, reprodutibilidade, explorabilidade, usuários afetados, descoberta), hoje considerado subjetivo e obsoleto. **p. 20**

Dupla extorsão. Combinação de cifrar os dados e ameaçar divulgar os que foram roubados; a tripla extorsão acrescenta DDoS ou pressão a clientes. **p. 11**

E

EF (Exposure Factor). Fração do valor do ativo que se perde em um único incidente, entre 0 e 1. **p. 20**

Elevation of privilege. Elevação de privilégio: obter permissões acima das concedidas, por exemplo trocando um parâmetro de perfil. **p. 20**

Encarregado (DPO). Pessoa indicada pelo controlador como canal de comunicação com os titulares e a ANPD. **p. 27**

Engenharia social. Manipulação psicológica de pessoas para obter informações, acessos ou ações, explorando confiança, urgência e autoridade. **p. 11**

Entidade externa. Elemento fora do controle do sistema que interage com ele, como usuários e serviços de terceiros. **p. 20**

Envenenamento de cache DNS. Inserção de respostas falsas no cache de um resolvedor, redirecionando usuários para destinos controlados pelo atacante. **p. 11**

EPSS. Exploit Prediction Scoring System: estimativa do FIRST da probabilidade (0 a 1) de uma vulnerabilidade ser explorada nos próximos 30 dias. **p. 20**

Evento × incidente. Evento é qualquer ocorrência observável; incidente é um evento que compromete a confiabilidade, integridade ou disponibilidade, ou viola política. **p. 5**

Exploit. Técnica, código ou procedimento que aproveita uma vulnerabilidade específica para obter um efeito não autorizado. **p. 5**

F

FAIR. Factor Analysis of Information Risk: modelo de análise quantitativa que decompõe o risco em frequência e magnitude de perda, com estimativas calibradas. **p. 20**

— GLOSSÁRIO TÉCNICO

CONTINUAÇÃO

Falhar de forma segura (fail-safe/fail-secure). Quando um controle falha, o sistema deve cair em estado seguro (negar acesso), não em estado aberto. **p. 5**

Fileless malware. Ataque que opera na memória e usa recursos legítimos do sistema, deixando poucos arquivos para análise por antivírus. **p. 11**

Força bruta (brute force). Tentativa sistemática de combinações até acertar uma senha ou chave, online ou offline contra hashes roubados. **p. 11**

Fronteira de confiança (trust boundary). Ponto em que dados ou controle passam entre níveis de confiança diferentes; onde se concentram validação e autenticação. **p. 5**

G

GDPR. Regulamento Geral sobre a Proteção de Dados da União Europeia (2016/679), com multas de até 20 milhões de euros ou 4% do faturamento global. **p. 27**

Gestão de exceções. Processo para aprovar desvios de política com dono, justificativa, risco aceito, prazo e revisão. **p. 27**

Gestão de riscos. Processo contínuo de identificar, analisar, avaliar, tratar e monitorar riscos, alinhado ao contexto e aos objetivos da organização (ISO 31000, ISO/IEC 27005). **p. 20**

Gestão de vulnerabilidades. Ciclo contínuo de descobrir, priorizar, corrigir e verificar vulnerabilidades em sistemas e aplicações. **p. 20**

Governança de segurança. Conjunto de direção, responsabilidades e prestação de contas pelo qual a alta direção define o apetite a risco e cobra resultados de segurança. **p. 27**

Grupo de Implementação (IG). Nível de adoção dos CIS Controls conforme tamanho e risco da organização; IG1 é a higiene cibernética essencial. **p. 27**

H

Hacktivista. Agente que ataca por motivação política ou social, geralmente com DDoS, pichação de sites e vazamento de dados. **p. 11**

I

Impacto. Consequência medida de um incidente: financeira, operacional, legal, reputacional ou sobre pessoas. **p. 5**

Infostealer. Malware que coleta credenciais, cookies de sessão, carteiras e dados do navegador para revenda ou uso direto em fraudes. **p. 11**

Integridade. Propriedade de que a informação e os sistemas permaneçam exatos, completos e não alterados sem autorização. **p. 5**

IoC (Indicator of Compromise). Evidência observável de comprometimento: hash, IP, domínio, chave de registro, padrão de tráfego. **p. 11**

ISO/IEC 27001. Norma internacional, certificável, com requisitos para estabelecer, operar e melhorar um SGSI; a edição vigente é a de 2022. **p. 27**

ISO/IEC 27002. Norma de orientação que detalha como implementar os 93 controles do Anexo A da ISO/IEC 27001:2022; não é certificável. **p. 27**

K

Kerberoasting. Ataque que pede tickets de serviço Kerberos e tenta descobrir offline a senha da conta de serviço associada. **p. 11**

KEV (Known Exploited Vulnerabilities). Catálogo da CISA com vulnerabilidades que já estão sendo exploradas ativamente no mundo real. **p. 20**

KPI. Key Performance Indicator: indicador de desempenho de um controle ou processo. **p. 27**

KRI. Key Risk Indicator: indicador que sinaliza aumento da exposição ao risco. **p. 27**

L

LGPD. Lei Geral de Proteção de Dados (Lei nº 13.709/2018): regula o tratamento de dados pessoais no Brasil. **p. 27**

LINDDUN. Metodologia de modelagem de ameaças à privacidade: Linking, Identifying, Non-repudiation, Detecting, Data disclosure, Unawareness e Non-compliance. **p. 20**

Living off the land (LotL). Técnica de usar ferramentas já presentes no sistema (PowerShell, WMI, certutil) para atacar, o que dificulta distinguir de uso legítimo. **p. 11**

M

Malware. Software malicioso projetado para causar dano, roubar dados ou obter acesso não autorizado: vírus, worms, trojans, ransomware, spyware e outros. **p. 11**

Marco Civil da Internet. Lei nº 12.965/2014: estabelece princípios, direitos e deveres na internet, incluindo a guarda de registros de conexão e de acesso a aplicações. **p. 27**

Matriz de risco. Grade que cruza probabilidade e impacto (por exemplo 5×5) para classificar riscos em baixo, médio, alto e crítico. **p. 20**

Mediação completa. Princípio de Saltzer e Schroeder: todo acesso a todo objeto deve ser verificado quanto à autoridade, sem atalhos nem caches inseguros. **p. 5**

Menor privilégio. Princípio de conceder a cada identidade ou processo apenas as permissões mínimas necessárias, pelo menor tempo necessário. **p. 5**

MFA fatigue. Ataque que dispara muitas notificações de aprovação de MFA até a vítima aceitar por cansaço ou engano. **p. 11**

MITM (Man-in-the-Middle). Ataque em que o adversário se posiciona entre duas partes para ler ou alterar a comunicação sem que percebam. **p. 11**

MITRE ATT&CK. Base de conhecimento pública de táticas, técnicas e procedimentos de adversários, observados no mundo real; usada para detecção e planejamento defensivo. **p. 11**

Modelagem de ameaças. Atividade de identificar, durante o projeto, o que pode dar errado em um sistema e decidir como tratar cada ameaça. **p. 20**

MTTR. Mean Time To Remediate/Respond: tempo médio para corrigir uma vulnerabilidade ou responder a um incidente. **p. 20**

— GLOSSÁRIO TÉCNICO

CONTINUAÇÃO

N

Não repúdio. Impossibilidade de uma parte negar ter praticado uma ação, em geral por assinaturas digitais e registros íntegros. **p. 5**

NIS2. Diretiva (UE) 2022/2555 sobre segurança de redes e sistemas de entidades essenciais e importantes, com notificação de incidentes significativos. **p. 27**

NIST CSF 2.0. Cybersecurity Framework do NIST (2024): resultados organizados em seis funções (Govern, Identify, Protect, Detect, Respond, Recover). **p. 27**

NIST SP 800-171. Requisitos para proteger informações não classificadas controladas (CUI) em sistemas de organizações não federais. **p. 27**

NIST SP 800-53. Catálogo detalhado de controles de segurança e privacidade do NIST, organizado em 20 famílias; base das autorizações do governo dos EUA. **p. 27**

Nível (CSF Tier). Grau de rigor e integração da gestão de riscos de cibersegurança: parcial, ciente de risco, repetível ou adaptativo. **p. 27**

Norma (padrão interno). Documento obrigatório com requisitos objetivos e verificáveis que detalham a política, como regras de senha ou de classificação. **p. 27**

NVD (National Vulnerability Database). Base de dados de vulnerabilidades do NIST que enriquece CVEs com pontuação CVSS, CWE e produtos afetados. **p. 20**

O

Operador. Agente de tratamento que realiza o tratamento de dados pessoais em nome do controlador (LGPD). **p. 27**

Organismo de certificação. Entidade independente e acreditada que audita uma organização e emite o certificado de conformidade com uma norma. **p. 27**

OWASP SAMM. Software Assurance Maturity Model: modelo prescritivo de maturidade de segurança de software, com 5 funções de negócio e 15 práticas. **p. 27**

P

Pass-the-hash. Técnica em que o hash de uma credencial (por exemplo NTLM) roubado é usado para autenticar sem conhecer a senha. **p. 11**

Password spraying. Tentar poucas senhas comuns contra muitas contas, para evitar o bloqueio por tentativas excessivas em uma só conta. **p. 11**

PASTA. Process for Attack Simulation and Threat Analysis: metodologia de modelagem de ameaças em sete etapas, orientada ao risco de negócio. **p. 20**

PCI DSS. Payment Card Industry Data Security Standard: 12 requisitos para proteger dados de cartões de pagamento; versão vigente 4.0.1. **p. 27**

PDCA. Plan-Do-Check-Act: ciclo de melhoria contínua (planejar, fazer, verificar, agir) que estrutura os sistemas de gestão ISO. **p. 27**

Perfil (CSF Profile). Descrição da situação atual e da situação-alvo de uma organização segundo o CSF, com o plano para fechar a diferença. **p. 27**

Phishing. Fraude por mensagem (e-mail, site, SMS) que se passa por entidade confiável para induzir a pessoa a revelar dados ou executar algo. **p. 11**

Política de segurança da informação. Documento aprovado pela direção que declara princípios, papéis e regras de alto nível; é curto, estável e obrigatório. **p. 27**

Pretexting. Criação de um cenário falso e plausível para convencer alguém a entregar informações ou acessos. **p. 11**

Princípio de Kerckhoffs. A segurança de um sistema criptográfico deve depender apenas do segredo da chave, não do sigilo do algoritmo. **p. 5**

Princípios de Cialdini. Seis alavancas de persuasão: reciprocidade, compromisso e coerência, prova social, autoridade, afinidade e escassez. **p. 11**

Privacidade. Uso adequado de dados pessoais conforme finalidade e consentimento ou base legal; depende da segurança, mas é um objetivo distinto. **p. 5**

Procedimento. Descrição passo a passo de como executar uma atividade de segurança de forma consistente. **p. 27**

Pyramid of Pain. Modelo de David Bianco (2013) que ordena indicadores (hash, IP, domínio, artefatos, ferramentas, TTPs) pela dificuldade de o adversário trocá-los. **p. 11**

Q

Quishing. Phishing por QR Code malicioso, que leva o usuário a um site fraudulento ou a baixar um aplicativo malicioso. **p. 11**

R

RaaS (Ransomware-as-a-Service). Modelo em que desenvolvedores alugam o ransomware e a infraestrutura a afiliados, dividindo o resgate obtido. **p. 11**

Ransomware. Malware que cifra dados (e, cada vez mais, os exfiltra) e exige pagamento para restaurar o acesso ou evitar a divulgação. **p. 11**

Registro de riscos. Documento vivo que lista cada risco com ativo, ameaça, nível, tratamento, responsável, prazo e status. **p. 20**

Regra 3-2-1-1-0. Estratégia de backup: 3 cópias, em 2 mídias, 1 fora do local, 1 offline ou imutável e 0 erros na verificação de restauração. **p. 11**

Repudiation. Repúdio: negar ter praticado uma ação quando não há registro confiável que a comprove. **p. 20**

Resolução CD/ANPD nº 15/2024. Regulamento de comunicação de incidente de segurança: prazo de 3 dias úteis e registro por, no mínimo, 5 anos. **p. 27**

Responsabilização (accountability). Capacidade de atribuir ações a uma identidade única, por meio de registros confiáveis, para auditoria e investigação. **p. 5**

Risco. Combinação da probabilidade de uma ameaça explorar uma vulnerabilidade e do impacto resultante sobre um ativo. **p. 5**

Risco inerente. Nível de risco antes da aplicação de qualquer controle. **p. 20**

Risco residual. Risco que permanece depois de aplicados os controles; deve ficar dentro da tolerância da organização. **p. 20**

— GLOSSÁRIO TÉCNICO

CONTINUAÇÃO

Rootkit. Conjunto de técnicas que oculta a presença de um invasor no sistema, em geral atuando no kernel; o bootkit age na inicialização. **p. 11**

ROSI. Return on Security Investment: retorno de um controle, calculado como (redução do ALE menos o custo) dividido pelo custo. **p. 20**

RPO (Recovery Point Objective). Quantidade máxima de dados, medida em tempo, que a organização aceita perder entre o último backup e o incidente. **p. 11**

RTO (Recovery Time Objective). Tempo máximo tolerável para restabelecer um serviço após uma interrupção. **p. 11**

S

Safety (segurança operacional). Evita que falhas de sistemas causem danos físicos a pessoas ou ao ambiente (sinalização, intertravamento); difere de security, que trata de adversários. **p. 5**

Script kiddie. Atacante de baixa habilidade que usa ferramentas e scripts prontos criados por terceiros, sem compreender a fundo o que executa. **p. 11**

Secure by design. Segurança incorporada desde o projeto, e não adicionada depois; no fornecedor, assume a responsabilidade por padrões seguros. **p. 5**

Segurança da informação (SI). Proteção da informação, em qualquer meio, contra acesso, alteração, destruição ou indisponibilidade indevidos; abrange pessoas, processos e tecnologia. **p. 5**

SGSI (ISMS). Sistema de Gestão de Segurança da Informação: conjunto de políticas, processos e controles gerido de forma contínua, como na ISO/IEC 27001. **p. 27**

Shadow IT. Uso de sistemas e serviços sem conhecimento ou aprovação da área de TI, geralmente para contornar controles incômodos. **p. 5**

SIM swap. Fraude que transfere o número de telefone da vítima para um chip do atacante, para interceptar SMS e códigos de verificação. **p. 11**

SLE (Single Loss Expectancy). Perda esperada por ocorrência: valor do ativo multiplicado pelo fator de exposição. **p. 20**

Slowloris. Ataque de camada de aplicação que mantém muitas conexões HTTP abertas e lentas até esgotar a capacidade do servidor. **p. 11**

Sniffing. Captura passiva de tráfego de rede; só expõe conteúdo legível se o tráfego não estiver criptografado. **p. 11**

SOC 2. Relatório de auditoria independente (AICPA) sobre controles de um serviço segundo critérios de confiança; Tipo I (desenho) e Tipo II (eficácia). **p. 27**

Spear phishing. Phishing direcionado e personalizado a uma pessoa ou grupo específico, com informações reais do alvo. **p. 11**

Spoofing. Falsificação de identidade: fazer-se passar por outro usuário, serviço ou dispositivo. **p. 20**

SSVC. Stakeholder-Specific Vulnerability Categorization: árvore de decisão (CISA e SEI/CMU) que resulta em ações como acompanhar, atender ou agir. **p. 20**

STRIDE. Mnemônico de seis ameaças: Spoofing, Tampering, Repudiation, Information disclosure, Denial of service e Elevation of privilege. **p. 20**

Superfície de ataque. Conjunto de todos os pontos de entrada e saída de dados que um adversário pode tentar usar; reduzi-la diminui as oportunidades de ataque. **p. 5**

SYN flood. DDoS de protocolo que envia muitos pedidos de conexão TCP incompletos para esgotar a tabela de conexões do servidor; mitigado com SYN cookies. **p. 11**

T

Tailgating. Entrada física não autorizada seguindo uma pessoa autorizada por uma porta controlada. **p. 11**

Tampering. Adulteração não autorizada de dados, código ou mensagens em repouso ou em trânsito. **p. 20**

Tática, técnica e subtécnica (ATT&CK). Tática é o objetivo do adversário (o porquê); técnica e subtécnica descrevem como ele o alcança (o como). **p. 11**

Threat Modeling Manifesto. Documento de 2020 que reúne valores e princípios da modelagem de ameaças, como colaboração e refinamento contínuo. **p. 20**

Threat-informed defense. Estratégia de priorizar defesas com base em como os adversários relevantes realmente atuam, em geral usando o ATT&CK. **p. 11**

Titular. Pessoa natural a quem se referem os dados pessoais tratados. **p. 27**

Tolerância a risco. Desvio máximo aceitável em relação ao apetite; limite a partir do qual é preciso reagir. **p. 20**

Tratamento do risco. Escolha da resposta a um risco: mitigar, transferir, evitar ou aceitar. **p. 20**

Trojan (cavalo de troia). Malware disfarçado de programa legítimo que, uma vez executado pelo usuário, entrega outras funções maliciosas. **p. 11**

TTP. Táticas, Técnicas e Procedimentos: o modo de operar de um adversário; indicador de topo na Pyramid of Pain. **p. 11**

V

Vetor CVSS. Texto que codifica as métricas de uma vulnerabilidade, como CVSS:3.1/AV:N/AC:L/...; cada par métrica:valor responde a uma pergunta. **p. 20**

Vetor de ataque. Caminho usado para alcançar o alvo, como e-mail de phishing, serviço exposto, mídia removível ou fornecedor comprometido. **p. 5**

Vishing e smishing. Phishing por ligação de voz (vishing) e por SMS (smishing). **p. 11**

Vulnerabilidade. Fraqueza em um ativo, processo ou controle que pode ser explorada por uma ameaça: falha de código, configuração incorreta, política ausente. **p. 5**

W

Whaling. Phishing contra executivos e cargos de alto valor; muitas vezes associado a fraudes de pagamento (BEC). **p. 11**

Wiper. Malware destrutivo que apaga ou corrompe dados de forma irrecuperável, às vezes se passando por ransomware. **p. 11**

Worm (verme). Malware que se propaga sozinho pela rede, explorando vulnerabilidades, sem precisar de ação do usuário nem de um arquivo hospedeiro. **p. 11**

BONS ESTUDOS!



ESTUDAR · PRATICAR · PROTEGER · EVOLUIR

Segurança não é um produto: é um processo. Quem entende as ameaças, projeta com cuidado e verifica sempre constrói sistemas que merecem confiança. Continue estudando e praticando — de forma ética e autorizada.